



Privacy by design in software development - Day 1

Main points to consider

Larisa Gabudeanu – ISM – 2024

Grading laws and regulations (5 points in total)

- 1 point homework (will be available in Moodle after the course; deadline 12 January 2025, 23:00)
- 3 points exam
- 1 point activity in class (quiz on Moodle; group case study)
- **Recap meeting:** before exam

! Please use real name on Zoom/Slack !

Overview of topics

1. Correlation with information security issues
2. Data protection concepts
3. Processing basis for data processing: initial purpose vs. subsequent purposes
4. Controller vs processor
5. Liability sharing
6. Information notices (transparency principle)
7. Data subject rights and retention period
8. Profiling and automated decisions
9. Pseudo-anonymized data

1 of 9: Correlation with information security - OWASP Top 10 risk - Cryptographic Failures

- **Examples**

- Is any data transmitted in clear text? This concerns protocols such as HTTP, SMTP, and FTP. External internet traffic is especially dangerous. Verify all internal traffic e.g. between load balancers, web servers or back-end systems.
- Is sensitive data stored in clear text, including backups?
- Are any old or weak cryptographic algorithms used either by default or in older code?
- Are default crypto keys in use, weak crypto keys generated or re-used, or is proper key management or rotation missing?
- Is encryption not enforced, e.g. are any user agent (browser) security directives or headers missing?
- Does the user agent (e.g. app, mail client) not verify if the received server certificate is valid?

- **Technical and business impact**

- Access to confidential data and possibility to amend it.

- **Legal implications**

- Cybersecurity legislation obligations, data protection obligations (security measures, access management, data minimization, need to know principle), commercial liability of IT security, specific regulatory provisions, criminal law angles

1 of 9: Correlation with information security - OWASP Top 10 risk - Security Logging and Monitoring Failures

- **Examples**

- Auditable events, such as logins, failed logins, and high-value transactions are not logged.
- Warnings and errors generate no, inadequate, or unclear log messages.
- Logs of applications and APIs are not monitored for suspicious activity.
- Logs are only stored locally.
- Appropriate alerting thresholds and response escalation processes are not in place or effective

- **Technical and business impact**

- Most successful attacks start with vulnerability probing. Allowing such probes to continue can raise the likelihood of successful exploit to nearly 100%. In 2022, identifying a breach took an average of 277 days – plenty of time for damage to be inflicted (according to IBM data breach report).

- **Legal implications**

- Cybersecurity legislation obligations, data protection obligations (minimization, access management, security measures, data breach notification), commercial liability of IT security.

1 of 9: Correlation with information security

Types of negative consequences for lack of compliance with data protection legislation:

- **Fines up to 4% of the worldwide turnover**
- Payment of prejudice incurred by individuals
- Payment of prejudice/costs incurred by co-contractors
- **Suspension or ceasing of the data processing**
- **Reputational impact**

1 of 9: Correlation with information security

France

- Lack of security measures for web application that lead to personal data (including ID cards) being publicly accessible (real estate company – EUR 400,000)
- Lack of proper **authentication method** (insurance company – EUR 180,000)

Norway

- Lack of security measures for **authentication** in mobile application (school – EUR 203,000)
- Lack of proper security measures for **authentication** (local authority – EUR 170,000)

Italy

- Lack of proper security measures on a web application of a data processor (online voting platform – EUR 50,000)

Lithuania

- Lack of security measures for web application (payment service provider – EUR 61,500)

UK

- Issues with security of web application (airline company – EUR 204.6 mil)
- Lack of proper assessment of IT system purchased and lack of implementation of security measures (hotel company – EUR 110.3 mil)

The Netherlands

- Lack of proper access management implementation (hospital – EUR 460,000)

Poland

- Lack of security measures implemented (online retail company – EUR 644,000)

1 of 9: Correlation with information security

Bulgaria

- Lack of proper security measures (fiscal authority – EUR 2.6mil)
- Lack of proper security measures for confidentiality of data, including ID cards and biometric data (bank – EUR 511,000)

Germany

- Lack of proper encryption in (social media company – EUR 20,000)

Malta

- Lack of proper security measures on a web application which led to data being publicly available (public authority – EUR 5,000)

Portugal

- Improper **access management** (hospital – EUR 400,000)

The Czech Republic

- Lack of proper security measures implemented (credit broker EUR 1,165)

<http://www.enforcementtracker.com/>

Romania

- Customer transaction **data available in clear text on the website** (law services company)
- Online accounts not having proper security measures implemented (online retail company)
- Lack of **encryption of data at rest** (police office)
- Lack of measures to ensure confidentiality and prevent unauthorized disclosure (fiscal authority)
- Lack of proper **policies and procedures** in place for ensuring confidentiality of data (retail company)

2 of 9: Data protection concepts: Personal data definition

- **any information**

- objective data about an individual (such as a client's job)
- subjective data about an individual (such as a client's risk rating).

- **related to a natural person**

- (a) pertaining to an **individual** (such as the car purchased through a leasing agreement)
- (b) has an **influence on or is influenced by an individual** (such as the predisposition to certain illness)
- (c) are in the **physical or geographical vicinity of an individual** or its objects (such as location of merchants where individuals usually shop in the evening, as this may refer indirectly to the home location of the individuals).

- that **identifies or makes identifiable** a natural person – e.g. groups of individuals

- either through data held by the controller or data that the controller may obtain – not clearly defined concept

Special types of personal data – article 9 GDPR – e.g. biometrics for identification, health data, criminal records, politic views.

2 of 9: Data protection concepts: Personal data definition

- EXERCISE – identify personal data (yes/no):
 1. IP address
 2. CNP – unique national identification number
 3. First and last name of an individual
 4. Primary key in a client database

[yes/no] – [reason why yes/no]

2 of 9: Data protection concepts: Personal data definition

- EXERCISE – identify personal data (yes/no):
 1. IP address – yes, if the exact individual can be identified or identifiable – e.g. a company for its employees as long as the allocation IPs are logged
 2. CNP – unique national identification number – yes, if the person having this information can CNP introduce in a database/excel/google search/etc to obtain
 3. First and last name of an individual – yes, if the name is uncommon and the individual can be identified having this information in a database/google search/etc; no, if the name is common and the user cannot be identified in a database/google search/etc
 4. Primary key in a client database – yes, if the person holding this information can lookup additional data about the individual by introducing the primary key in a database/excel/etc

2 of 9: Data protection concepts: Personal data definition

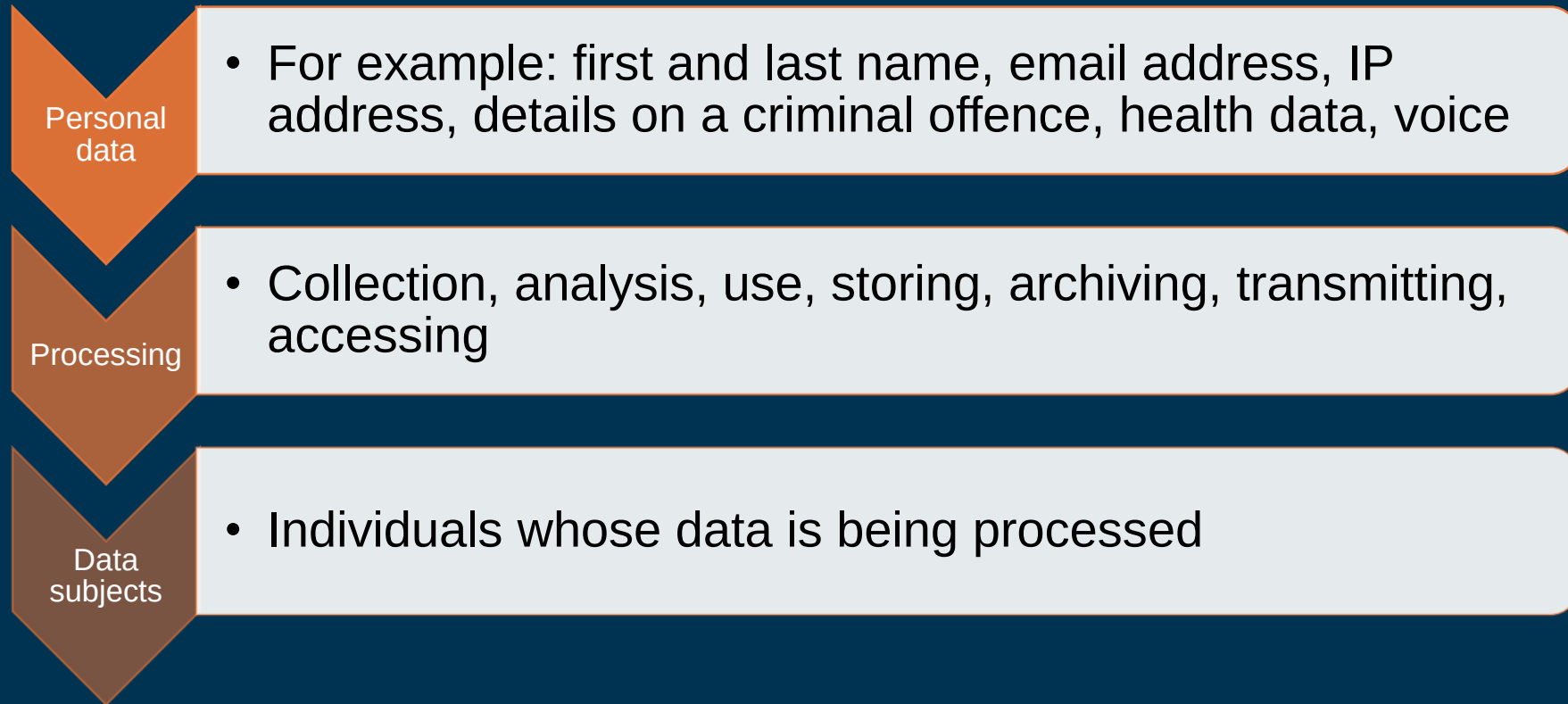
- Identify personal data:

1. **Logs of a web application** – yes, if they contain personal data that identifies or makes identifiable an individual
2. **Voice of client calling the call center of a company** – yes, if the calling IT system records the call and holds other information identifying the individual
3. **Predictions of diseases based on health app data** – yes, if the data in the health app identifies or makes identifiable an individual. Generally this is the case given the sign up information and location tracking.
4. **“Client 123 drinks coffee from the coffee shop on Street X each morning at exactly 8am”** – yes, if the client ID “123” can be introduced in a system and leads to the client being identified or if the other information in this statement can be searched in a database and lead to the client being identified or identifiable.
5. **Cookies** – yes, if the data held in the cookie is personal data identifying a visitor or makes the visitor identifiable

2 of 9: Data protection concepts: Personal data definition

- Identify personal data:
 1. **National ID card** – yes, there are sufficient data there to identify an individual
 2. **“team lead in the DevOps team in Bank A likes fast cars”** – yes, if the individual can be identified or a group of individuals being team lead in the DevOps team in Bank A can be identified – e.g. on social media
 3. **John Doe likes coffee** – no, as the name is too common
 4. **Video surveillance of entrance in a building** – no, if no face recognition exists; yes, if the recorded video is viewed by the police, etc to identify an individual they are looking for
 5. **“some students of ISM master programme like coffee”** – yes, if, for example, additional information about coffee is found on social media about an ISM master student

2 of 9: Data protection concepts: Data processing activity



- ✓ **Data processing purpose** identification as basis for analysis. Example: internet banking app having multiple data flows – making payments, obtaining loans, shopping in the market place for partner products, obtaining insurance.

2 of 9: Data protection concepts: Data processing activity

Storing in the cloud or on a co-contractor's server – relevant aspects to analyse

- **Location of data on the primary server**
- **Location of all replications, transiting data and back-ups**
- **Location of data processed by sub-contractors of the hosting entity**
- **Collection of metadata or telemetry data**
- **Further analysis if data outside the EU - main points:**
 - If decision about adequate level of protection of personal data – issued by the EC
 - If binding corporate rules (transfer within an organisation having locations in countries outside the EU)
 - If standard model clauses (agreement with hosting entity based on EC template) + supplementary measures for protection of personal data

2 of 9: Data processing activities - Exercise

Identify the data processing activities:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring

2. Who are the data subjects?
3. What personal data is processed?
4. How is the data processed?

1. Who processes the personal data?

2 of 9: Data processing activities - Exercise

Identify the data processing activities:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring

1. Who processes the personal data?

Client actions in the client app data processing: The insurance company (Insurance Inc) and the app developer (DevOps Inc)

Vehicle monitoring data processing: The insurance company and the app developer (DevOps Inc)

Credit scoring: Bank

2. Who are the data subjects?

3. What personal data is processed?

4. How is the data processed?

2 of 9: Data processing activities - Exercise

Identify the data processing activities:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring

1. Who processes the personal data?

Client actions in the client app data processing: The insurance company (Insurance Inc) and the app developer (DevOps Inc)

Vehicle monitoring data processing: The insurance company and the app developer (DevOps Inc)

Credit scoring: Bank

2. Who are the data subjects?

Client actions in the client app data processing: the clients and potential clients of Insurance Inc

Vehicle monitoring data processing: The clients of the insurance company (if they are individuals), the drivers of the vehicles (if the clients are legal entities or if someone else is driving aside from the clients)

Credit scoring: clients of Insurance Inc

3. What personal data is processed?

4. How is the data processed?

2 of 9: Data processing activities - Exercise

Identify the data processing activities:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring

1. Who processes the personal data?

Client actions in the client app data processing: The insurance company (Insurance Inc) and the app developer (DevOps Inc)

Vehicle monitoring data processing: The insurance company and the app developer (DevOps Inc)

Credit scoring: Bank

2. Who are the data subjects?

Client actions in the client app data processing: the clients and potential clients of Insurance Inc

Vehicle monitoring data processing: The clients of the insurance company (if they are individuals), the drivers of the vehicles (if the clients are legal entities or if someone else is driving aside from the clients)

Credit scoring: clients of Insurance Inc

3. What personal data is processed?

Client actions in the client app data processing: identification data, insurance contract data, insurance claims data

Vehicle monitoring data processing: location data, metadata on driving manner (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state), client data

Credit scoring: identification data, insurance contract data, insurance claims data, location data, metadata on driving manner

4. How is the data processed?

2 of 9: Data processing activities - Exercise

Identify the data processing activities:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring

1. Who processes the personal data?

Client actions in the client app data processing: The insurance company (Insurance Inc) and the app developer (DevOps Inc)

Vehicle monitoring data processing: The insurance company and the app developer (DevOps Inc)

Credit scoring: Bank

2. Who are the data subjects?

Client actions in the client app data processing: the clients and potential clients of Insurance Inc

Vehicle monitoring data processing: The clients of the insurance company (if they are individuals), the drivers of the vehicles (if the clients are legal entities or if someone else is driving aside from the clients)

Credit scoring: clients of Insurance Inc

3. What personal data is processed?

Client actions in the client app data processing: identification data, insurance contract data, insurance claims data

Vehicle monitoring data processing: location data, metadata on driving manner (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state), client data

Credit scoring: identification data, insurance contract data, insurance claims data, location data, metadata on driving manner

4. How is the data processed?

Client actions in the client app data processing: collection, storing, analysis, transfer, deletion

Vehicle monitoring data processing: collection, storing, analysis, deletion, transfer

Credit scoring: collection(indirectly), storing, analysis, deletion

3 of 9: Processing basis

Main types of processing basis usually applicable (other types are listed under article 6 of GDPR):

- Performance of agreement with the data subject (including negotiation phase)
- Legal obligation of the data controller (not of anyone else) – e.g. registration with authorities, reporting
- Legitimate interest of a data controller
- Consent (expressly given, freely given, informed, easily accessible, plain language)

- For **subsequent data processing (different purposes)**, separate analysis should be made.

Examples:

1. data initially processed for usage of travel app used for identifying bugs and improving app;
2. user data used subsequently for marketing towards the users

Compatibility test:

- **Similarity** between the initial and subsequent purpose
- **Reasonable expectation** of the data subject with respect to the subsequent purpose
- **Types of personal data** processed and the **consequences** of the processing on the data subject
- Measures implemented for **preventing negative consequences** on data subjects

***Intra-group transfers** – analysis of legal basis every time. Including in cases where a company holds IT apps/infrastructure for entire group

3 of 9: Processing basis

For the use case:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring
- ✓ It obtains data from a credit scoring agency for its potential clients
- ✓ It obtains leads from an e-commerce website (name, telephone number and email address)
- ✓ It sends annual reports to its supervisory authority

What is the processing basis for each processing activity?

3 of 9: Processing basis

For the use case:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring
- ✓ It obtains data from a credit scoring agency for its potential clients
- ✓ It obtains leads from an e-commerce website (name, telephone number and email address)
- ✓ It sends annual reports to its supervisory authority

What is the processing basis for each processing activity performed by a data controller?

Processing activities:

Insurance services:

Vehicle monitoring to prevent stealing:

Vehicle monitoring for insurance policy tailoring:

Credit scoring for bank:

Credit scoring for Insurance Inc.:

Lead collection from e-commerce website:

Reports to authority:

3 of 9: Processing basis

For the use case:

- ✓ Insurance company (Insurance Inc)
- ✓ It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- ✓ For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- ✓ The app is hosted with its developer (DevOps Inc)
- ✓ DevOps Inc performs maintenance services and bug fixing
- ✓ It sends the data to a bank within the same group as the insurance company for credit scoring
- ✓ It obtains data from a credit scoring agency for its potential clients
- ✓ It obtains leads from an e-commerce website (name, telephone number and email address)
- ✓ It sends annual reports to its supervisory authority

What is the processing basis for each processing activity performed by a data controller?

Insurance services: performance of agreement
Vehicle monitoring to prevent stealing: legitimate interest

Vehicle monitoring for insurance policy tailoring: consent

Credit scoring for bank: consent

Credit scoring for Insurance Inc.: it depends; could be consent or legitimate interest

Lead collection from e-commerce website: consent

Reports to authority: legal obligation

4 of 9: Data controller vs. data processor - Key characteristics

- **Controller**

- Entity which (alone or together with others); when jointly with others => joint controllers
- Determines the purposes; and
- Determines the means of processing.

- **Processor**

- Entity processing personal data on behalf of the controller; and
- Acting as per the instructions of the controller.

Examples:

- ✓ **IT maintenance services** – generally, processor, as it receives instructions from its clients on how to handle the data
- ✓ **Lawyer in a law firm** – controller, as the lawyer acts upon its specific legislation and code of conduct, thus determining the purpose and means of processing
- ✓ **Cloud service provider offering storage** – processor, as it receives instructions from its client on how to handle the data
- ✓ **Company offering SOC services** (incident monitoring and analysis) – generally, processor, as it receives instructions from its client on how to handle the data
- ✓ **IT development services** – generally, for providing this type of service, access to personal data should not exist, except for specific situations. If personal data is processed, processor, as it receives instructions on how to handle the data from the beneficiary of the development services

4 of 9: Data controller vs. data processor

On-premises	IaaS	PaaS	SaaS
Applications	Applications	Applications	Applications
Data	Data	Data	Data
Runtime	Runtime	Runtime	Runtime
Middleware	Middleware	Middleware	Middleware
OS	OS	OS	OS
Virtualization	Virtualization	Virtualization	Virtualization
Servers	Servers	Servers	Servers
Storage	Storage	Storage	Storage
Networking	Networking	Networking	Networking

4 of 9: Data controller vs. data processor

- Insurance company (Insurance Inc)
- It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- The app is hosted with its developer (DevOps Inc)
- DevOps Inc performs maintenance services and bug fixing
- It sends the data to a bank within the same group as the insurance company for credit scoring
- It obtains data from a credit scoring agency for its potential clients
- It obtains leads from an e-commerce website (name, telephone number and email address)
- It sends annual reports to its supervisory authority
- It performs profiling of its clients holding a vehicle insurance through machines learning algorithms, especially based on the manner in which they drive (sensors within the smart car). This is used to adjust the amount of insurance premium that individual has to pay. Company GoodProfiling Inc is used for this activity.

What are the roles (data controller or data processor) for each entity mentioned for each data processing it performs

4 of 9: Data controller vs. data processor

- Insurance company (Insurance Inc)
- It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- The app is hosted with its developer (DevOps Inc)
- DevOps Inc performs maintenance services and bug fixing
- It sends the data to a bank within the same group as the insurance company for credit scoring
- It obtains data from a credit scoring agency for its potential clients
- It obtains leads from an e-commerce website (name, telephone number and email address)
- It sends annual reports to its supervisory authority
- It performs profiling of its clients holding a vehicle insurance through machines learning algorithms, especially based on the manner in which they drive (sensors within the smart car). This is used to adjust the amount of insurance premium that individual has to pay. Company GoodProfiling Inc is used for this activity.

What are the roles (data controller or data processor) for each entity mentioned for each data processing it performs

Insurance services:

Maintenance of app:

Vehicle monitoring to prevent stealing:

Vehicle monitoring for insurance policy tailoring:

Credit scoring for bank:

Credit scoring for Insurance Inc.:

Lead collection from e-commerce website:

Reports to authority:

4 of 9: Data controller vs. data processor

- Insurance company (Insurance Inc)
- It already has an application used by its customers (for contracts, new products) and non-customers (filing requests for offers)
- For vehicle insurances, the app contains data from sensors on the smart vehicles of the clients (e.g. speed, breaking patterns, fuel usage, wheel usage, time of driving session, driver tiredness state)
- The app is hosted with its developer (DevOps Inc)
- DevOps Inc performs maintenance services and bug fixing
- It sends the data to a bank within the same group as the insurance company for credit scoring
- It obtains data from a credit scoring agency for its potential clients
- It obtains leads from an e-commerce website (name, telephone number and email address)
- It sends annual reports to its supervisory authority
- It performs profiling of its clients holding a vehicle insurance through machines learning algorithms, especially based on the manner in which they drive (sensors within the smart car). This is used to adjust the amount of insurance premium that individual has to pay. Company GoodProfiling Inc is used for this activity.

What are the roles (data controller or data processor) for each entity mentioned for each data processing it performs

Insurance services: Insurance Inc – controller

Maintenance of app: DevOps Inc - processor

Vehicle monitoring to prevent stealing: Insurance Inc – controller

Vehicle monitoring for insurance policy tailoring: Insurance Inc – controller; GoodProfiling Inc – processor (in general)

Credit scoring for bank: Insurance Inc – controller; bank - controller

Credit scoring for Insurance Inc.: Insurance Inc – controller; credit scoring agency – controller

Lead collection from e-commerce website: Insurance Inc – controller; e-commerce website - controller

Reports to authority: Insurance Inc – controller; authority - controller

4 of 9: Controller vs. processor

Case study 1 of 2

- **Recruitment agency**

- Who establishes the **purpose**?

Depends; if the recruitment agency receives from the company a list of characteristics for the candidates, identified the candidates through various means

If the recruitment agency receives the CVs of the candidates from the company or very specific instructions on identifying the candidates directly, it may be qualified as a data processor

- Who sets-out the **means**?

Depends; generally, if the recruitment agency is a data controller, it also establishes the software it uses, means of transfer of data, storing of data, etc

If the recruitment agency is a data processor (less likely in practice), the controller would generally set out the means of processing.

4 of 9: Controller vs. processor

Case study 2 of 2

- **Web application created together by a travel agency, a hotel and an airline**
 - Who establishes the **purpose**? – all three entities
 - Who sets-out the **means**? – generally, all three entities
 - Who holds the **data**? – generally, it may be considered that the data is held by an entity on behalf of all three entities
 - Who has **direct access to the data**? – generally, all three entities

Thus, the three entities act as joint data controllers

5 of 9: Liability sharing

- Types of **potential claims** to be brought:
 - Penalties from authorities
 - Claims from data subjects
 - Claims from co-contractors
- Protection against payment of claims:
 - **Contractual limitation** of amount to be paid for liability
 - **Exclusion of liability** in certain specific situations listed in the agreement
 - **Limitation on costs incurred** for assistance to the co-contractor, especially in court proceedings or when addressing data subject requests
 - Recital 78 GDPR – detailing the obligation to implement **privacy by design**

5 of 9: Liability sharing

Case study

- **GPS tracking of car fleet**

(using third party software off the shelf hosted by the third party vendor, with a certain level of maintenance services)

Important questions to ask

- **Who has access to data?** Access management and proper logging thereof is important in case of a data breach and when assigning liability
- **Who runs the reports?** Access management and proper logging thereof is important in case of a data breach and when assigning liability
- **Where is the server located?** The entity holding the server will generally be responsible to implement security measures. The location of the server (EU/non-EU) may lead to liability on the side of the data controller (if it did not verify/take appropriate steps) or on the side of the data processor (GPS service provider) if it moved data outside of the EU without letting the data controller know, for example.
- **Build-in opt-out for employees when off-work?** This is a privacy ensuring mechanism usually built-into the GPS tracker. It should be requested by the data controller. Lack of such mechanism may lead to damages being requested by individuals from the data controller.
- **Privacy by design obligation for software developer?** Generally, yes. Nevertheless, the data controller is also responsible for choosing appropriate software having proper privacy mechanisms in place.

In case of a data breach on the server where the software is stored, who is liable? Explain why.

Depends on the contract. Generally, if the data breach occurred with the GPS service provider (who also stored the tracking data) because of a lack of proper security measure implementation by the GPS service provider, the GPS service provider is liable towards the individuals affected.

6 of 9: Information notices (Transparency principle)

- **Clear, concise**, complete, layer approach/entire information notice
- **Evidence** needed for being brought to the attention of the data subject – e.g. tick boxes saved in the database
- Specific content – articles 13 and 14 of the GDPR
- **Easily accessible** for users when online (direct access or layered approach)
- Provided **prior to any data processing** takes place (with some exemptions)

7 of 9: Data subject rights and retention period

- Focus on **right of erasure** and **right of access** – need to implement technical possibilities to address individual's rights when they file a request in this respect; anonymisation instead of deletion (see Working Party Article 29 opinion on anonymisation on Sakai)
- **Data minimisation principle** (limitation of types of personal data and of processing period) – in this case **limited retention period** based on the need to process data
- Implementation of deletion mechanism: automated or manual (correlated with other IT systems)
- **Data portability/data access** – legacy systems? Redundancy within systems?
- Structured and unstructured data
- Propagation throughout the IT systems
- Know your architecture; know your data – call center example

8 of 9: Profiling and automated decisions

Concept

Profiling represents:

- any form of automated processing of personal data
- used to evaluate (including to analyse or to predict) certain personal aspects relating to a natural person

Limitations to profiling: e.g. need for consent in case of intrusive profiling (such as, processing of data not expected by data subject, which can cause harm to the data subject or discriminate him/her)

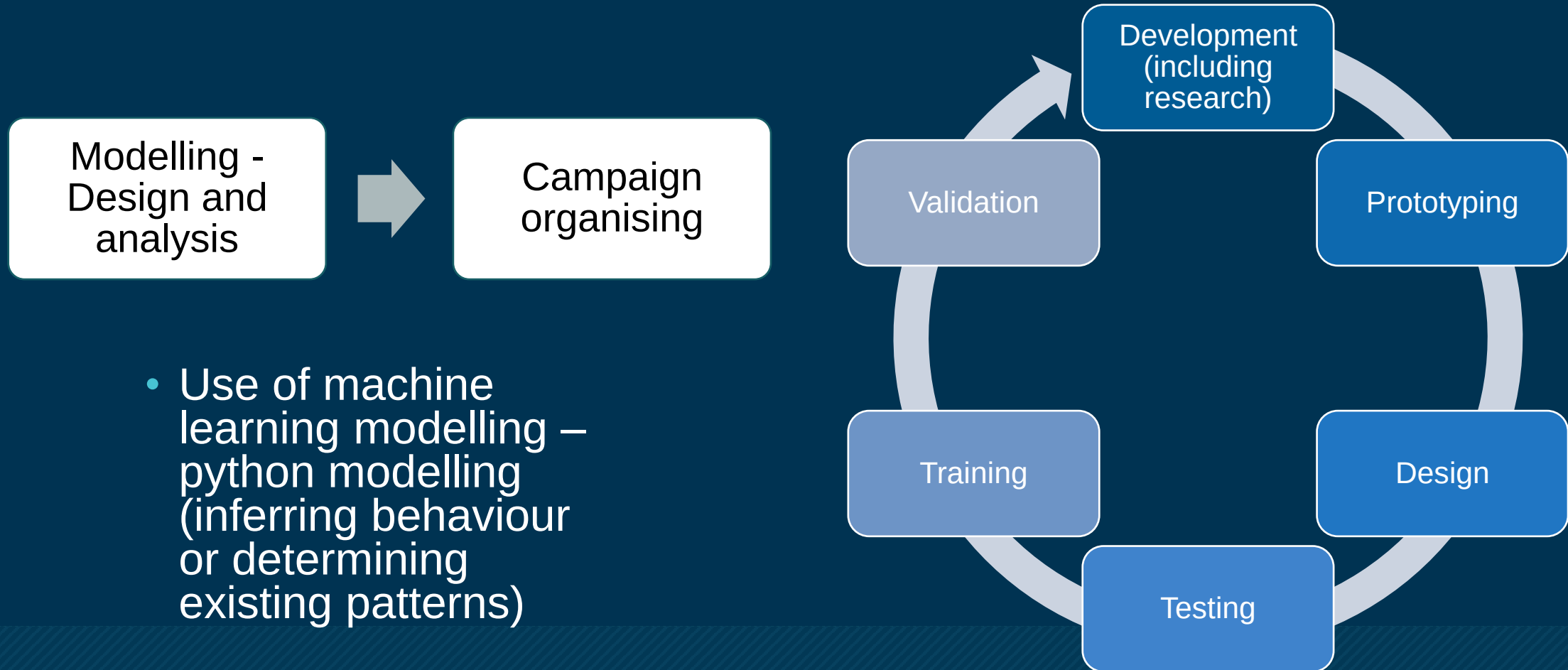
Limitations for automated decisions:

- a decision to be taken solely on automated processing (including profiling); and
- the decision to produce legal effects concerning him or her or similarly significant affects him.

Exemptions to limitations for automated decisions:

- necessity for a contract; or
- authorised by the law of EU or member states; or
- explicit consent of data subject.

8 of 9: Profiling - Data analytics for marketing purposes



8 of 9: Profiling: Use of third parties for analytics

- Controller vs processor
 - Third party used for development/training/validation of the model
 - Third party giving data to the organisation for analysis by the organisation
- Who decides the **purpose and the data to be used** for training?
- How **granular does a purpose** have to be established for an entity to become controller?
- Is it relevant **where the data was collected from and by whom?**

8 of 9: Profiling and automated decisions

Potential risks

- Discrimination or unfair treatment
- Limits rights or denies an opportunity
- Biased/harms (CNIL, Solove, no receiving same offers)
- Lack of predictability
- Certain sectors of society may not be represented
- Jeopardize of data accuracy
- Data broking

Example: **Social media app** – using profiles of its users for marketing purposes (on behalf of other companies – e.g. banks, retail stores)

8 of 9: Profiling and automated decisions

To do list

- ❑ Data minimization – proportionality principle
- ❑ Accuracy of data stored
- ❑ Anonymisation/Pseudonymation
- ❑ Retention period
- ❑ Information provided to data subjects – including structuring of the profiling and envisaged consequences of such processing
- ❑ Right to rectification
- ❑ Right to object (specifics for marketing activities)
- ❑ Implementing appropriate safeguards
- ❑ Data protection impact assessment (data analysis specific in certain situations provided by law)
- ❑ AI ethics – new direction – EU reports; Global Privacy Assembly working group report

Example: **Social media app** – using profiles of its users for marketing purposes (on behalf of other companies – e.g. banks, retail stores)

8 of 9 Profiling: Anonymisation/Pseudonymisation

Technique/Risks	Singling-out risk (identifying all data pertaining to an individual)	Linkage risk (link data from various sources)	Inference risk (inferred data from multiple sources may lead to identification)
Pseudonymisation (replacing one attribute (typically a unique attribute) in a record by another)	Yes	Yes	Yes
Noise addition (randomisation technique that modifies the value of attributes in a dataset in such a manner in order to make this value less accurate, while maintaining the overall distribution)	Yes	Maybe	Maybe
Substitution (randomisation technique)	Yes	Yes	Maybe
k-anonymity (generalisation technique under which attributes are suppressed or generalized until each row is identical with at least k-1 other rows)	No	Yes	Yes
l-diversity (generalisation technique that builds on k-anonymity, ensuring that within each equivalence class created by k-anonymity, every attribute has at least l different values)	No	Yes	Maybe
Differential privacy (generalisation technique that only releases for analysis (including by third parties) sub-sets of data (based on specific queries applied to the initial dataset) which have been anonymised based on the other techniques)	Maybe	Maybe	Maybe
Pseudonymisation through hashing/tokenisation	Yes	Yes	Maybe

9 of 9: Pseudo-anonymized data - Case study

- **Database of financial transactions from a bank account**

(pseudo-anonymization of such data)

- Limitations around the use for creating new products or for marketing campaigns
- (i) it is still possible to identify a data subject? (ii) it is still possible to link records/entries relating to the same data subject? or (iii) information can be deduced/inferred regarding a data subject?
- Is the data subject identified or identifiable by using any means likely reasonable to be used by either a data controller or a third party?

How you would approach pseudo-anonymisation of financial transactions from the bank account of an individual in order to keep them relevant for data analytics? Think of the types of data included in your bank statement.

Relevant legislation and guidance

- GDPR (EU Regulation 2016/679)
- Law no. 190/2018
- Law no. 506/2004
- Working Party Article 29 guidance
- EDPB guidance
- OASIS – privacy by design guidance for engineers
- ISO/IEC 29134 – data protection impact assessment
- ISO/IEC 27701 – data protection management
- NIST 800-37 – security and data protection risk assessment
- NIST 800-53 – security and data protection controls
- NIST privacy framework – draft
- AICPA/GAPP- methodology for privacy maturity assessment
- OECD 108 Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data



Questions?

Email: larisagabudeanu@gmail.com

Overview

1. Privacy by design concept
2. Data oriented principles
 - A. Minimise/Separate/Abstract/Hide
 - B. Anonymisation and Pseudonymisation
3. Process oriented principles
 - A. Inform
 - B. Control
 - C. Implement
 - D. Demonstrate
4. Privacy by design in SDLC (Software Development Life Cycle)
 - A. Requirements
 - B. Design
 - C. Coding
 - D. Testing
 - E. Deployment
 - F. Maintenance / Change request
5. Additional resources

1 of 5 Privacy by design concept

Privacy by design – Including data protection (including IT security concepts) and integration with IT systems – entails technical, organisational and internal process adjustments, including CIA (confidentiality, integrity, availability).

Privacy engineering – A suite of design mechanisms and IT system integration with respect to data protection aspects, together with risk management concerning consequences on individuals.

Objective	Description
Predictability	Individuals, business owners and users being aware of the data processing
Management	Possibility to access, rectify or delete data
Unlinkability	Anonymisation/pseudonymisation of personal data when these are not needed



1 of 5 Privacy by design concept - usefulness

Integration of data protection specifics from the design phase (when the architecture of the IT system is created)

Ensure proper functioning of the IT system (user-centric approach)

Ensures integration with legacy IT systems

Avoids delays in deployment and changes to the initial architecture

Correlation with legal, technical and commercial requirements

1 of 5 Privacy by design - type of data processing

N o	Types of data processi ng	Applicable principles	Implementation
1	Collection	MINIMISE	Establish the data needed before collection. Delete unnecessary data. Ensure accuracy of data.
		AGGREGATE	Anonymisation at the local level (in the source IT system)
		HIDE	Lack of more correlation than necessary, encryption of data, identity masking
		INFORM	Providing information concerning the data processing to individuals
		CONTROL	Mechanism for granting/revoking consent
2	Analysis	AGGREGATE	Anonymisation
		HIDE	Anonymisation, using of only necessary data
3	Storing	HIDE	Encryption; authentication and rights management
		SEPARATE	Storing data in a distributed/decentralised manner, where possible
4	Use	AGGREGATE	Anonymisation; data quality measures
5	All types	IMPLEMENT/DEMON STRATE	Implementation of internal procedures, maintaining audit trails for proving compliance

2 of 5 Data oriented principles

Minimisation of data and limiting the possibility for identification of an individual:

Minimise	Limiting as much as possible the processing of personal data (only necessary processing) and anonymisation/pseudonomysation when possible.
Separate	Separating the data processing in tables/databases/IT systems/different networks.
Abstract	Limiting the granular processing of personal data
Hide	Hiding personal data in order to limit unauthorised access, including through access rights or interconnection with other IT systems

2.A of 5 Minimise/Separate/Abstract/Hide

- Using third party code/libraries – checking data collection/storing/processing
- **Token/session ID** – Limited/no personal data included; only encrypted/hashed data
- **Crash reports, telemetric data, metadata** –data minimisation for collection and aggregation analysis
- In an IT system chain (e.g. web server, middleware), each component to hold only necessary data
- Use of sensor data/location data only when actually necessary
- **Logs and metadata** – limited personal data, only if needed
- **Restricting access to data** – only individuals that need access and for the period they need it (internally and externally)
- Checking that third parties accessing personal data have proper agreements in place (DPAs)
- **Respecting data quality – synchronization with master IT systems**
- **Analyse the public data available in general to a potential attacker to identify an individual** - e.g. public data, google ID, device fingerprinting

2.A of 5 Minimise/Separate/Abstract/Hide

Collection minimisation

- Collecting only data needed at that moment, not collecting just in case it may be useful later on

Disclosure minimisation

- Limited disclosure of data internally or externally to only necessary situations

Replication/copying data minimisation

- Limiting the replication of data in multiple IT system (relevant also for keeping data accuracy) – e.g. temporary database for pre-processing data held on a web server

Centralising data minimisation

- Avoid a single point of failure

Minimising the possibility to correlate data

- Limiting the possibility of an attacker to correlate a significant number of data

Minimising retention period

- Identification of the minimum period necessary for keeping data (legal requirements, business need) before deleting them

2.A of 5 Minimise/Separate/Abstract/Hide

- **Saving data on the user device (permanent storage/cache)** – security analysis (encryption, secure access to storage area), deletion upon session termination
- **Multi-tenancy** – segregation and restriction of access among tenant (also in terms of logs, encryption keys held in vaults)
- **Not including personal data in communication** – e.g. email body, email title, names of files
- **Deletion of data temporary held in certain systems**
- **Visualisation of data/access through VPN to analyse data (e.g. for bugs)** – only if necessary and if there is a processing basis
- **Limitations due to legacy systems**
- **Examples of separation:**
 - Separation of data with higher level of confidentiality from lower level of confidentiality
 - Separation of data in database tables and limiting access to needed tables/attributes
 - Separation of access based on the zero-trust architecture (identity management, asset management, application authentication, network segmentation, and threat intelligence)

2.A of 5 EXERCISE - Minimise/Separate/Abstract/Hide

What would you analyse for the following to ensure minimise/separate/abstract/hide principle?

1. Use of external libraries for tracking of activity of users in a mobile application from which you receive an aggregation on various filters
2. Registration process that involves picture of ID and video call to compare images for identification of an individual

2.A of 5 Anonymisation and pseudonymisation

Anonymisation - unidentifiable

- Without unique identifiers in the IT ecosystem
- Without contact/identification data
- k-anonymity, l-diversity, differential privacy, etc
- No characteristics of the individual collected

Pseudonymisation – identifiable with reasonable efforts

- Without unique identifiers in the IT ecosystem
- Contact/identification data kept separately from the rest of the data
- Without common attributes between databases
- Collection of characteristics of individuals at a granular level

Pseudonymisation – identification with little effort

- Without unique identifiers in the IT ecosystem
- Contact/identification data kept separately from the rest of the data
- With common attributes between databases

Identified or identifiable

- Unique identifiers in the IT ecosystem
- Contact/identification data (CNP, ID card picture) kept in the same place as the other data

2.A of 5 EXERCISE - Anonymisation and pseudonymisation

- Anonymised data or pseudonymised data?
 1. Only banking transactions from a bank account (e.g. similar to bank excerpt information)
 2. Google analytics data held by Google for a single website

3 of 5 Process oriented principles

Information	Informing individuals on the data processing adequately from a content and timing perspective	• Description of data processing for IT systems • Bringing to the attention of individuals before commencing the data processing • Information about data protection incidents, if necessary according to legal requirements
Control	Individuals have control on the processing manner – especially consent and exercise of rights according to GDPR (access, restriction, deletion)	• Technical functionalities in the IT system or process management within the organisation • Performing the information steps before obtaining consent
Implementation	Adequate implementation of data protection requirements	• Access management • Implementation of specific measures resulting from the data protection analysis and from internal procedures • Ensuring implementation of requests by sub-contractors/co-contractors
Demonstrate	Ensuring the possibility to prove: - the measures implemented according to data protection legal requirements - The actions of individuals (e.g. users, clients) in terms of data protection	• Logging and audit trail

3.A of 5 Inform

- To identify if information notice should be followed by consent (if consent processing basis)
- Offer transparency and predictability to individuals
- No pre-ticking of tick boxes – need for actual action by the client to acknowledge information notice/to consent
- **The information notice should address:**
 - data collected from individuals
 - data obtained from third parties – e.g. vendors, marketing agencies, group companies
 - data sent to third parties – e.g. vendors, marketing agencies, group companies, authorities
- **Information notice should be:**
 - **brought to the attention of individuals prior to collection/processing of data**
example: registration form
 - accessible in the application and on the website:
Question: Why both?
 - clear, specific for the data processing relating to the IT system and subsequent data processing in the IT ecosystem of the organisation

3.A of 5 EXERCISE - Inform

How would you bring to the attention of individuals the information notice in the below cases?

1. Personal data obtained from a customer research agency in relation to customer views on your organisation's product
2. A new feature of the mobile app (added in the new release and updated automatically in the mobile phones of individuals) requires the use of location and other sensors in order to function properly

3.B of 5 Control

- **The user should be able to configure certain elements concerning personal data – e.g. cookies, tracking actions, granting/revoking consent**
- **Master IT system to be set for ensuring the accuracy of personal data**
- **Sending the user preferences to all third parties involved in the process if they have different IT systems than the organization ones**
- **Propagation of changed user preferences throughout all systems**

3.B of 5 EXERCISE - Control

How would you design the IT system in the following scenarios to address control of individuals on their data?

1. A mobile app for notification about sales in the user's favourite online stores – user wants to stop receiving notifications about specific stores
2. Google analytics cookies on a website

3.C of 5 Implementation

Processing basis specifics

- **APIs** – Identify legal basis for connecting – creation in a modular manner in order to reflect need to know principle (same for any reports)
- Collecting data/ Disclosing data – interconnection with IT systems (internal or external)

Accuracy of data

- **Validating use input** – specific business requirements/technical requirements
- **Integrity of data** – being able to prove that such data was introduced by the client himself/herself (audit trail)
- If data replicated in multiple IT systems (internal or external) – instant synchronization mechanism (exception – DWH, Data lakes); identify master IT system
- **Deletion of data no longer accurate (from back-ups, replications, middleware)**

3.C of 5 Implementation

CIA specifics

- Sending personal data via email vs sending links to clients in email
- Including in the code/architecture triggers in case of data breach – integration with SIEM solution
- **Use of video/audio/location/sensors** – stop when timeout
- **Timeout** in case of inactivity
- **Data at rest and data in transit – proper encryption/protection mechanisms**

3.C of 5 Implementation

Disclosure of data to the organisation

- Transfer from a vendor, IT maintenance company, for proof of concept, for sector research
- Transfer from group companies
- Transfer from authorities

- Identification of processing basis (having an agreement in place does not mean that any data can be transferred for any purpose)
- **Adequate information notice to individuals**
- **Identification of any other requirements**
- Location of data stored/location of accessing data (for the entire supply chain)

Disclosure of data by the organisation

- Transfer to a vendor, IT maintenance company, for proof of concept, for sector research
- Transfer to group companies
- Transfer to authorities

3.C of 5 EXERCISE - Implementation

How would you approach data accuracy in the following situations?

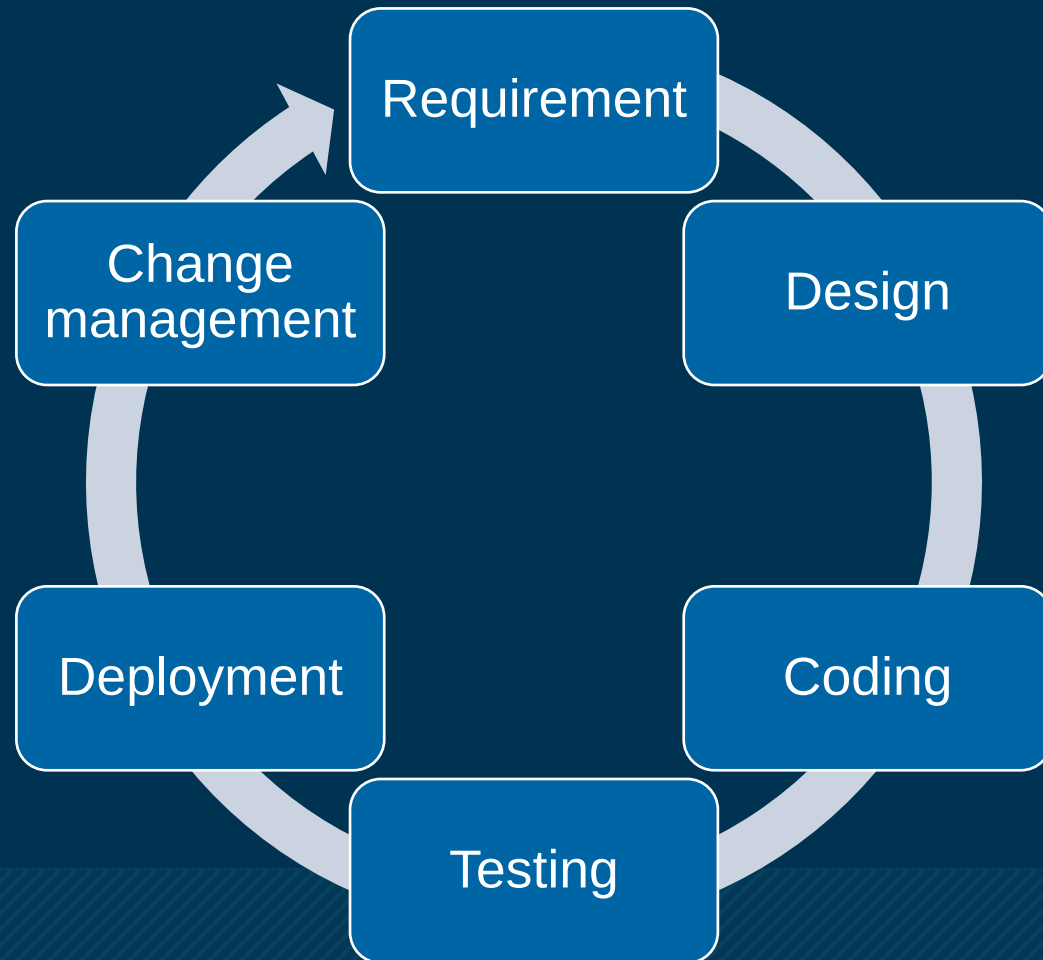
1. New user registered with first and last name, email address and telephone number
2. Email address in the core database about users can be updated from multiple sources:
 - From mobile app by users
 - From web application by users
 - By employees through their employee interface when a client calls the call center

3.D of 5 Demonstrate

Documentation

- For actions of the user that produce legal effects in terms of data protection
- **Proper time stamping**
- **Data protection analysis – DPIA/balancing tests**
- Proper documentation in the registry of processing activities

4 of 5 Privacy by design in SDLC



4 of 5 Privacy analysis life cycle

Requirement

Difficult to define at the outset; risk appetite

Offering of guidance

Templates for specific data processing

Design

Legacy and group systems

Correlation with existing systems

Define requirements for initial design

Coding

Static code analysis

Third party source code

Third party libraries

Testing

UX vs privacy

Privacy testing

White box testing

Deployment

Implementation steps

Regular reviews

Audits

Change management

Identification of impact on personal data

Triggers for privacy analysis

Restarting the SDLC

4 of 5 Privacy by design in SDLC

Specifics depending on development methodology

Waterfall

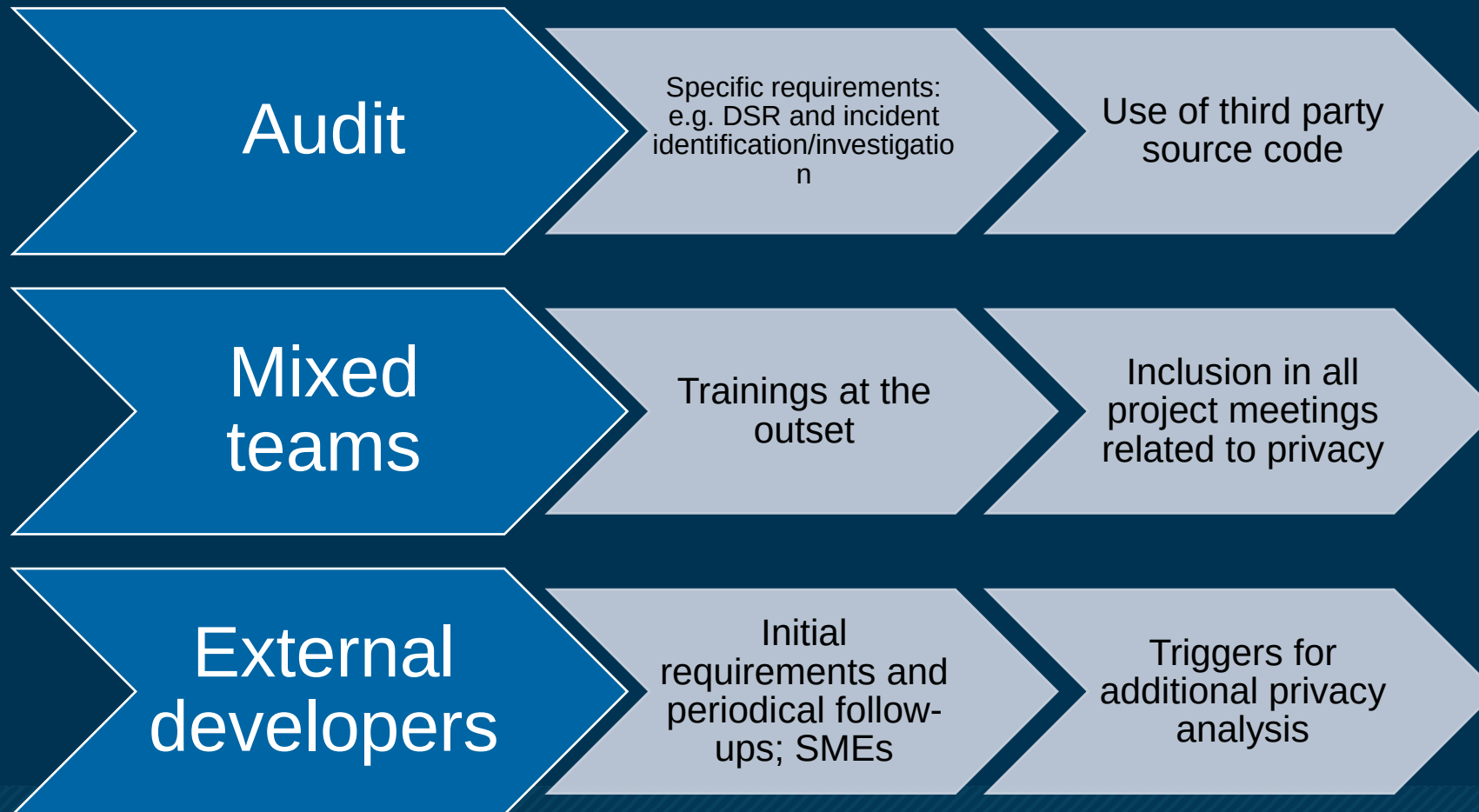
- **Outset of project** – the general requirements are detailed
- **End of project** – formal assessment of project is performed

Agile/Scrum

- **Each sprint** – for each change business, privacy and developers discuss privacy implications
- **Each meeting** – real-time awareness of changes to architecture

4 of 5 Privacy by design in SDLC

Use of third parties



4 of 5 Privacy by design in SDLC - Data life cycle

	Collection from an individual	Collection from other entities	Storing	Processing for the initial purpose	Processing for a subsequent process	Disclosure of data to other entities (e.g. vendors) for the initial collection purpose	Transfer of data as per legal obligations – e.g. to authorities	Deletion of data
Inform – data transparency	X	X	To include upon collection	Identified upon collection	To be included when collecting/when establishing subsequent purpose	To be included upon collection	To be included upon collection	To be included upon collection
Identification of the specific data processing purpose	X	X	Identified upon collection	Identified upon collection	X	Identified upon collection	Identified upon collection	-
Data minimisation	X	X	-	X	X	X	X	X
Identification of adequate processing basis	X	X	Identified upon collection	Identified upon collection	X	Identified upon collection	Identified upon collection	-
Need to know principle (access management)	X	X	X	X	X	X	X	X
Data accuracy	X	X	-	X	X	X	X	-
Establishing retention period and deletion mechanism	X	X	X	X	X	X	X	-
Technical and organisational security measures (CIA)	X	X	X	X	X	X	X	X

4 of 5 Privacy by design in SDLC - matrix

	Minimise/Separate/Abstract/Hide	Anonymise/Pseudonymisation	Inform	Control	Implement	Demonstrate
Requirements	X	X	X	X	X	-
Design	X	X	X	X	X	X
Coding	X	X	X	X	X	X
Testing	X	X	X	X	X	-
Deployment	X	X	-	-	X	-
Maintenance/Change requests	X	X	X	X	X	X

4.A of 5 Requirements

- **Identify from the outset** the personal data aspects that have to be integrated with the business requirements
- Off-the-shelf with customisation – from the request for proposal phase

4.B of 5 Design

- **Proactiv, not reactive** – identify the processing activities from the outset of the design phase – data protection requirements may require changes to the IT solution/architecture
- Involve the data protection team/DPO
- Requirements differ on the types of IT system – client facing, employee users only, backend, middleware, microservices, API
- API – analysis at creation and at usage
- Including incident identification/response in the design
- Including data subject request handling/retention period in the design
- Data protection process/controls/measures to be included in the UML, IT architecture, UX/UI parts

4.C of 5 Coding

- Proper handling of exceptions – in order to prevent unauthorised data disclosure
- Have in mind the data processing activities and correlation with other IT systems when coding
- Analysis of third party libraries/third party code
- If new features/processing activities added, re-evaluation

4.D of 5 Testing

- Preparing testing early – identify the use cases needed for testing – to create synthetic data/anonymised data
- Limited exemption when testing with real/production data – properly analysed before using and properly documented/monitored
- Specific access for testing environment based on need to test and limited in time

4.E of 5 Deployment in production

- Ensuring that the environment to which the deployment is made is identical in terms of configurations/data processing/data transfer to the testing/development environment
- Important moment for implementing access management/segregation of duties properly

4.F of 5 Maintenance/Change Management

- To be analysed for any initiative to change a data processing activity (which includes changing the features/structure of an IT system)
- **Examples:**
 - New interconnection of an IT system to send data to another IT system
 - New module with new features added to the IT system
 - The IT system front-end is changed to include tracking of users

4.F of 5 EXERCISE - Maintenance/Change Management

What is the most efficient control to ensure privacy by design analysis in case of changes to an IT system?

- A. Mandatory approval to be obtained from the data protection department before entering into production of the new version of the IT system
- B. Mandatory involved of the data protection department when the change is being designed
- C. Notification sent to the data protection department when the change is approved

5 of 5 Further reading

- OASIS – Privacy by Design Documentation for Software Engineers (<http://docs.oasis-open.org/pbd-se/pbd-se/v1.0/pbd-se-v1.0.html>)
- OASIS – Annex Guide to Privacy by Design Documentation for Software Engineers (<http://docs.oasis-open.org/pbd-se/pbd-se-annex/v1.0/pbd-se-annex-v1.0.html>)
- MITRE – Privacy engineering (<https://www.mitre.org/publications/technical-papers/mitre%E2%80%99s-privacy-engineering-tools-and-their-use-in-a-privacy>)
- ENISA – Privacy by design si privacy by default (<https://www.enisa.europa.eu/publications/privacy-and-data-protection-by-design>)
- Spain DPA – Guidance privacy by design and default (https://www.aepd.es/sites/default/files/2019-12/guia-privacidad-desde-diseno_en.pdf)
- LIND(D)UN – privacy threat modelling (<https://www.linddun.org/downloads>)
- Norwegian data protection authority – privacy by design guidelines (<https://www.datatilsynet.no/en/about-privacy/virksomhetenes-plikter/innebygd-personvern/data-protection-by-design-and-by-default/>)
- National Institute of Standards and Technology (NIST) – NISTIR 8062 An Introduction to Privacy Engineering and Risk Management in Federal Systems, Jan 2017 (<https://nvlpubs.nist.gov/nistpubs/ir/2017/NIST.IR.8062.pdf>)
- ISO 27550:2019 – Information technology — Security techniques — Privacy engineering for system life cycle processes
- ISO 29100:2011 – Information technology — Security techniques — Privacy framework



Questions?

Email: larisagabudeanu@gmail.com



Rights over software & EU data and cybersecurity legislation

Larisa Gabudeanu – ISM – 2024-2025

Overview of topics

1. Definitions
2. Copyright over software and databases
3. Company and its employees/individual contractors
4. Company and external software development company
5. Off-the-shelf software
6. Customising off-the-shelf software
7. Embedding third party source code/libraries into your source code
8. Best practices in NDAs (non disclosure agreements)
9. PETs
10. EU data and cybersecurity legislation
11. Cyber crime – main criminal offences

1 of 11: Definitions

- Software
 - Any form of an application, operating system or any type of computer program
 - In any computer language
 - In the form of source code, object code; and
 - Any preparatory material for creating the software and any manuals
- Database
 - A collection of data or any other independent items
 - Protected through copyright or not
 - Placed in a systematic manner
 - Accessible through electronic or other means
- Creator of a database
 - Natural or legal person
 - That made a substantial qualitative or quantitative in obtaining, verifying or presenting the content of the database

1 of 11: EXERCISE - Definitions

- Which of the above is protected by software copyright?
 1. A script that you use to compare if two entries from two databases are identical
 2. The Google Analytics script references in websites
 3. Cookies
 4. Macro written by you in excel
 5. Third party library you include in Python code
 6. App in Play Store for Android
 7. Design architecture
 8. User manual
 9. Implementation document outlining the features of the software

Write on Slack for one use case: [no. of use case] – [yes/no] – [reason why]

1 of 11: EXERCISE - Definitions

- Which of the below is a database?
 1. IMDB
 2. SIEM database
 3. A MongoDB database for a fintech
 4. An Oracle database for an online retail store
 5. Antivirus signature database
 6. CVEs database (<https://cve.mitre.org/>)

Write on Slack for one use case: [no. of use case] – [yes/no] – [reason why]

2 of 11: Copyright over software and databases

- What is covered by protection under the law?
 - Source code and supporting documentation
 - Databases
 - Not the programming languages
 - Not the functionality of software
 - Not the graphical interface
 - Not the ideas and processes at the core/basis of the software
 - Not the principles and mathematical concepts

2 of 11: Copyright over software and databases

- What actions are NOT permitted on copyrighted software?
 - Bare copying
 - Having the same structures and the same steps, in the same order, for the same issue (if a substantial part of the source code was copied in this manner) – debated in case law
 - Without right, permanent or temporary reproduction (partially or fully)
 - Without right, translate and/or change a software
 - Distribution or rental of the software
- What actions are permitted on copyrighted software?
 - Back-ups needed for using the software
 - Analysing and testing a software in order to understand its principles
 - Interoperability
 - Error correction

3 of 11: Company and its employees/individual contractors

- **Default:**
 - Company holds rights of software created by its employees upon its instructions/as per their job description
 - Company does not hold rights over software created by individual contractors upon its instructions
- **Best practice:** Clause in agreement to clarify situation
- **Cross-border issues** – generally depends on legislation in the countries involved
- **Collaborative approach**
 - Default (co-authors who can decide jointly on rights over software)
 - Usually express clauses in agreements

4 of 11: Company and external software development company

- Specifics for software development agreement:
 - Instructions/business and technical **requirements** – add method to address in agile
 - **Cooperation platform** used – whose has access to it/back-ups
 - **Skills** required from external developers; subcontracting specifics
 - **Timeline and acceptance steps** – add method to address in agile
 - **Copyright** over software to be detailed – including not final forms
 - Maintenance and dependencies on provider (**exit strategy**)
 - Source code in **escrow**?
 - **Warranty** – especially over ownership of source code included in software
 - Integration with **legacy systems** – needed skills, approaches and liability, unknown integration aspects
 - **Updates** – legal or business requirements
 - **Testing** – use cases, who performs the tests and acceptance
 - Use of **production data** or synthetic data
 - **Non-compete**
 - **Confidentiality clause** – especially about business or confidential data the external developer has access to

5 of 11: Off-the-shelf software

- Standard right to use the software
- Can be customised – changes made by entities having right to amend the software
- For integration, depending on the type of licensing (e.g. open source or not)

7 of 11: Embedding third party source code/libraries into your source code

- 4 software freedoms of the Free Software Foundation
 - *Freedom to use/run the software (freedom 0).*
 - *Freedom to analyse the software (freedom 1).*
 - *Freedom to redistribute the software (freedom 2).*
 - *Freedom to improve/change the software (freedom 3)*
- Copyleft: Mechanism to ensure freedoms for all users
 - use the same open source license on composite/derivative work and on redistribution
 - provide access to initial source code and to composite/derivative work
- Not possible to have “proprietary” software

7 of 11: Embedding third party source code/libraries into your source code

- **Technical benefits**
 - Faster development
 - Auditability
 - Interoperability
 - Easy to customise
- **Technical risks**
 - Immaturity of some OSS
 - Stability of new versions of the OSS
- **Business benefits**
 - Low costs
 - Fast development of new business lines and new products
 - New skill developed by developers
- **Business risks**
 - Potential vulnerabilities due to lack of maturity of OSS
 - Lack of guarantee

7 of 11: Embedding third party source code/libraries into your source code

License Type	Characteristic	Examples
Permissive	- Few restrictions for reuse and redistribution - May restrict derivative/composed work	BSD, MIT, Apache Software, License v2
“Weak” copyleft	Copyleft on the original work and not on derivative/composed work	LGPL, MPL, CPL
“Strong” copyleft	Copyleft on all redistributed work and on derivative/composed works	GPL2, GPL3, EURL

8 of 11: Best practices in NDAs (non disclosure agreements)

- **Define the confidential data** protected through the NDA (trade secrets – specific legislation at EU level)
- **Define exclusions** – data publicly available, data obtained through other sources, data developed independently, data already known by the co-contractor
- Detail the **disclosure right** for the confidential data: auditors, authorities, shareholders
- Detail the persons **to whom the NDA applies** – e.g. all employees of the parties and obligations of the parties to ensure confidentiality from their employees
- NDA to be signed **before access to data is given** – together mainly with the data processing agreement
- **Monitor implementation** of the NDA – e.g. remote connections to be monitored during maintenance

*TRADE SECRET

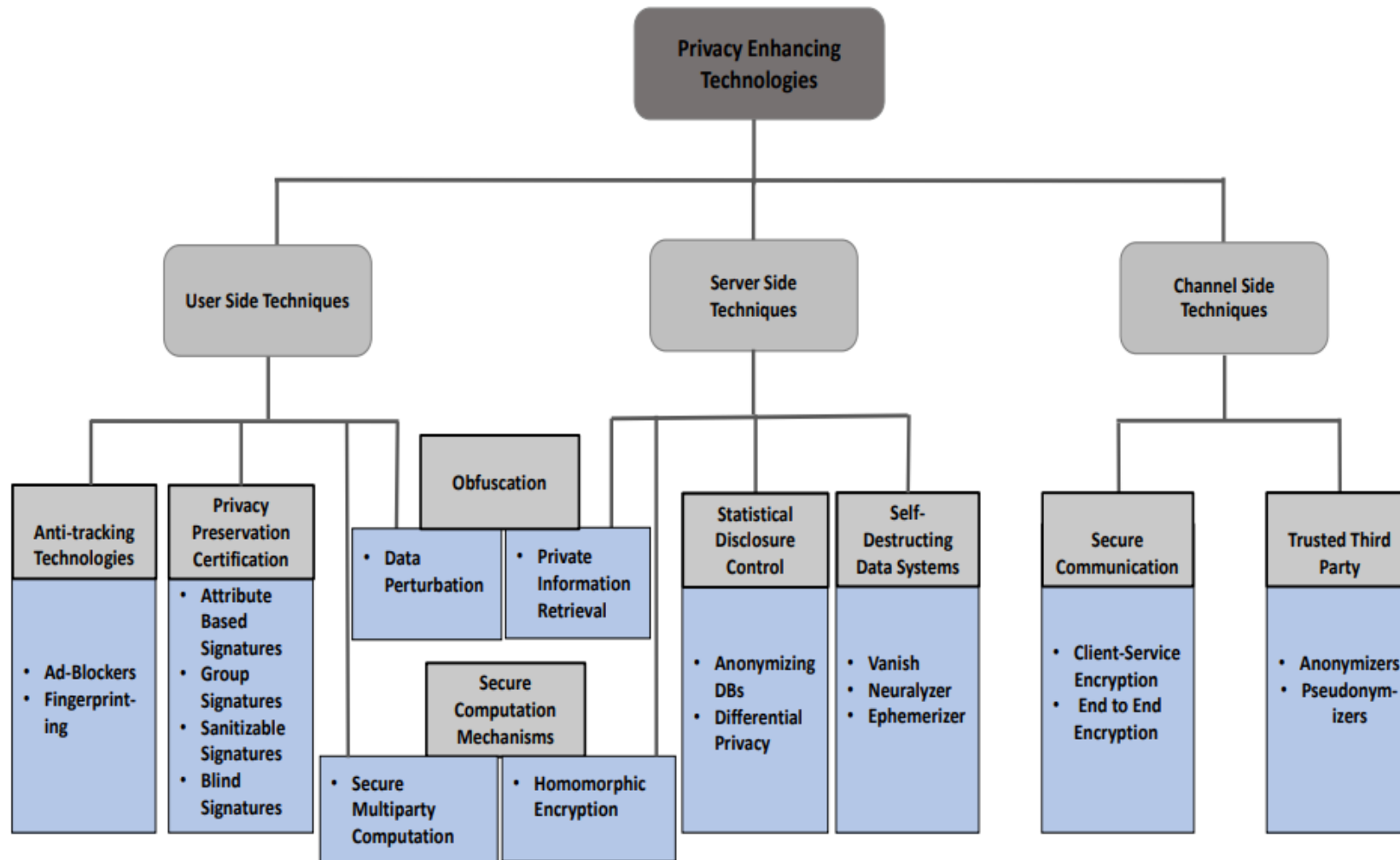
- Not generally known and not readily available to the persons who usually work in the area/field covered by the trade secret
- Has an economic value for the company invoking the trade secret
- The company having control over the trade secret has taken reasonable steps (under the given situation) to keep such information secret

8 of 11: EXERCISE - Best practices in NDAs

- What would you consider confidential during software development?
 1. UX/UI
 2. API format after it was made public for using by third parties
 3. Business requirements
 4. Source code
 5. Budget for the project
 6. Technologies used for development
 7. Technologies used for legacy systems with which the new software will interconnect

Write on Slack for one use case: [no. of use case] – [yes/no] – [reason why]

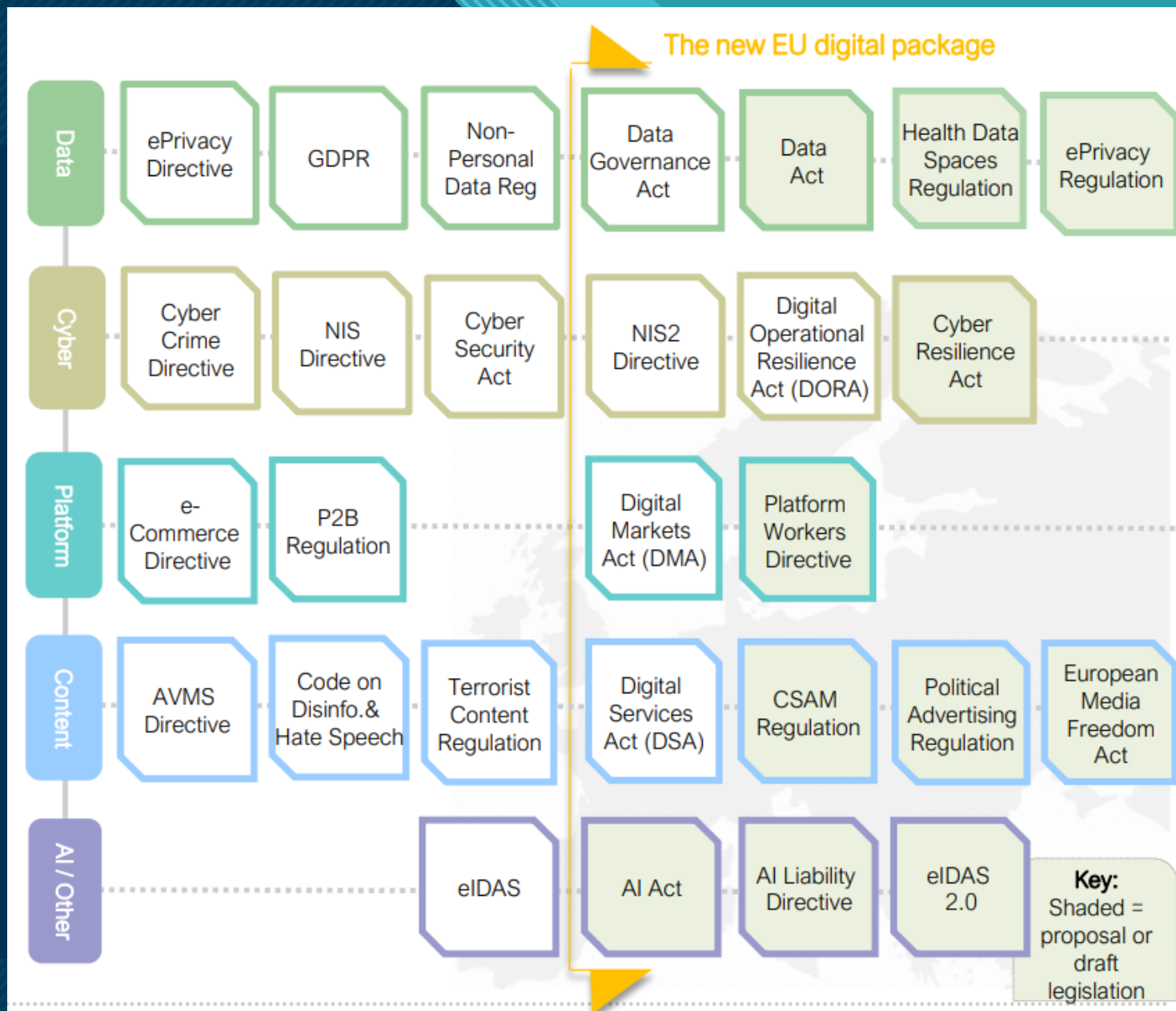
9 of 11 PETs - Purpose: protect personal data



9 of 11 PETs

- Purpose: protect personal data
- Examples – Top 10 PETs in 2023:
 - **Homomorphic Encryption** - encryption method enabling computational operations on encrypted data.
 - **Secure multi-party computation** - a subfield of homomorphic encryption. The difference is that users are able to compute values from multiple encrypted data sources.
 - **Differential privacy** - cryptographic algorithm includes a “statistical noise” layer to the dataset; it enables to describe patterns of groups within the dataset while maintaining the privacy of individuals.
 - **Zero-knowledge proofs** - uses a set of cryptographic algorithms that allow information to be validated without revealing data that proves it.
 - **Obfuscation**
 - **Pseudonymization** – examples: <https://ico.org.uk/media/1061/anonymisation-code.pdf>
 - **Data minimisation**
 - **Communication anonymizers** - replace online identity (IP address, email address) with disposal/one-time untraceable identity
 - **Synthetic data generation**
 - **Federated learning** - machine learning technique that trains an algorithm across multiple decentralized edge devices or servers holding local data samples, without exchanging them

10 of 11 EU data and cybersecurity legislation



10 of 11 EU data and cybersecurity legislation

- **NIS Directive** – Romanian implementation – examples of provisions
 - ❖ Entities in scope for operators of essential services – e.g. from the banking sector, transportation, health sector, energy sector
 - ❖ Obligations include: implementation of security measures
- **DORA** (Digital Operational Resilience Act) – examples of provisions
 - ❖ Third party risk assessments
 - ❖ External red teaming exercise
 - ❖ ICT risk assessment
 - ❖ Resilience testing
- **Cloud** use in financial services legal provisions – EIOPA, EBA
- **Internet banking** local requirements for authorisation
- **Remote identification of individuals** – local requirements for authorisation

11 of 11 Cyber crime - main criminal offences

Art. 360 Cod Penal: Accesul ilegal la un sistem informatic

- (1) Accesul, fără drept, la un sistem informatic se pedepsește cu închisoare de la 3 luni la 3 ani sau cu amendă.
- (2) Fapta prevăzută în alin. (1), săvârșită în scopul obținerii de date informatice, se pedepsește cu închisoarea de la 6 luni la 5 ani.
- (3) Dacă fapta prevăzută în alin. (1) a fost săvârșită cu privire la un sistem informatic la care, prin intermediul unor proceduri, dispozitive sau programe specializate, accesul este restricționat sau interzis pentru anumite categorii de utilizatori, pedeapsa este închisoarea de la 2 la 7 ani.

Relevant aspects – **Illegal access to IT systems**:

- **Action sanctioned: Accessing**
- **Without right** – e.g. without a contract, without the consent of the owner of the IT system
- **IT system** (definition: orice dispozitiv sau ansamblu de dispozitive interconectate sau aflate în relație funcțională, dintre care unul sau mai multe asigură prelucrarea automată a datelor, cu ajutorul unui program informatic)
- **Purpose of accessing – relevant for increased sanctions**
- **Use of specialized tools – relevant for increased sanctions**
- **Attempts are sanctioned**

11 of 11 Cyber crime - main criminal offences

Art. 361: Interceptarea ilegală a unei transmisii de date informatice

(1) Interceptarea, fără drept, a unei transmisii de date informatice care nu este publică și care este destinată unui sistem informatic, provine dintr-un asemenea sistem sau se efectuează în cadrul unui sistem informatic se pedepsește cu închisoarea de la unu la 5 ani.

(2) Cu aceeași pedeapsă se sancționează și interceptarea, fără drept, a unei emisii electromagnetice provenite dintr-un sistem informatic, ce conține date informatice care nu sunt publice.

Relevant aspects – **Illegal interception of data transmission:**

- Action sanctioned: Interception
- Transmission of data that is not public
- Attempts are sanctioned

11 of 11 Cyber crime - main criminal offences

Art. 362: Alterarea integrității datelor informatice

Fapta de a modifica, șterge sau deteriora date informatice ori de a restricționa accesul la aceste date, fără drept, se pedepsește cu închisoarea de la unu la 5 ani.

Relevant aspects – **Altering the integrity of data:**

- Action sanctioned: modification, deletion or corruption/deterioration of data, restricting access to data
- Without right – e.g. without contract or consent
- Attempt are sanctioned

11 of 11 Cyber crime - main criminal offences

Art. 363: Perturbarea funcționării sistemelor informatice

Fapta de a perturba grav, fără drept, funcționarea unui sistem informatic, prin introducerea, transmiterea, modificarea, ștergerea sau deteriorarea datelor informatice sau prin restricționarea accesului la date informatice, se pedepsește cu închisoarea de la 2 la 7 ani.

Relevant aspects – **Perturbing the functioning of IT systems:**

- Action sanctioned: Perturbing the functioning of an IT system through input of data, transfer, change, deletion or deterioration of data
- Attempts are sanctioned

11 of 11 Cyber crime - main criminal offences

Art. 364: Transferul neautorizat de date informatice

Transferul neautorizat de date dintr-un sistem informatic sau dintr-un mijloc de stocare a datelor informatice se pedepsește cu închisoarea de la unu la 5 ani.

Relevant aspects – **Unauthorised transfer of data:**

- Action sanctioned: Unauthorised transfer
- Attempts are sanctioned

Relevant legislation

- Law no. 8/1996 on copyright
- Emergency Ordinance no. 25/2018 on trade secrets
- Law no 11/1991 on protection from unfair competition
- Romanian Criminal Code
- Law no 362/2018 – implementing the NIS1.0 directive
- Order no 1323/2020 – security measures NIS1.0 directive



Questions?

Email: larisagabudeanu@gmail.com



Cyber security legislation – not for exam

ISM Master, Overview 2024-2025

AGENDA

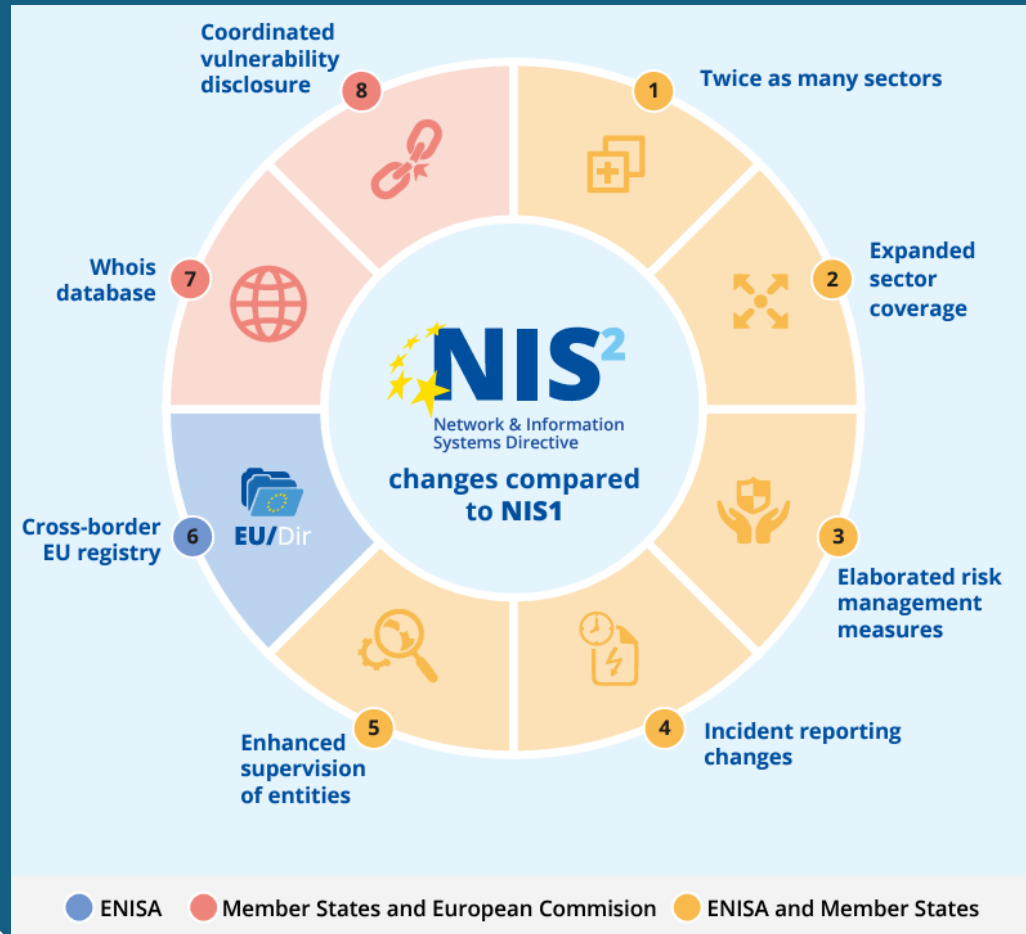
NIS 2

Artificial Intelligence Act

DORA

Cyber Resilience Act

NIS 2 Directive



7 Whois database



Member States are expected to maintain a dedicated database of domain name registration data, including contact details for registrants and administrators, to enhance DNS security, stability, and resilience.

8 Coordinated vulnerability disclosure

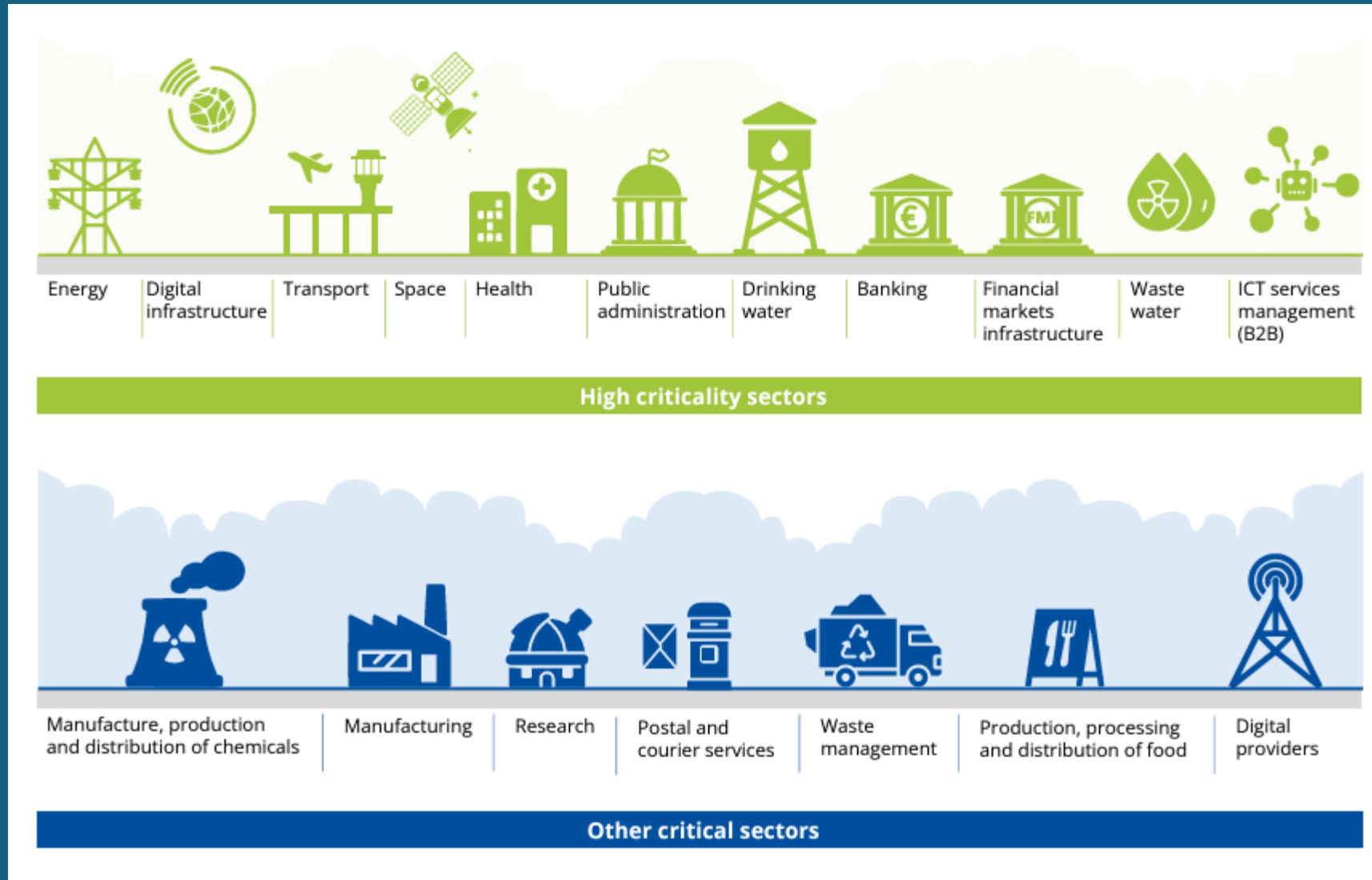


A structured process for reporting vulnerabilities to manufacturers or service providers, is introduced, to ensure vulnerabilities are addressed and resolved before being made public.

NIS 2 Directive

1 Twice as many sectors 	2 Expanded sector coverage 	3 Elaborated risk management measures 
With NIS2 more sectors / subsectors are in scope based on their degree of digitalization, interconnectedness and how crucial they are for the economy and society.	A size threshold rule distinguishes essential from important entities, while Member States can include smaller, high-risk entities.	An expanded list of proportional, all-hazards cybersecurity risk management measures is introduced, along with increased responsibilities for top management.
4 Incident reporting changes 	5 Supervision of entities 	6 Cross-border EU Registry 
More structured incident notification obligations apply to in-scope organisations, with specific deadlines for incidents which have a 'significant impact' on the provision of their services.	A more coherent framework for stronger supervision is introduced, that encompasses minimum supervisory means, distinct regimes for essential and important entities, and cross-border collaboration mechanisms.	An EU-wide registry for cross-border entities where Member States will register their main establishments and branches is foreseen for enhanced supervision.

NIS 2 Directive



NIS 2 Directive

Entities within the identified sectors are categorized as **essential entities** or **important entities**

depending on factors such as size, sector and criticality.

Essential entities

- **High criticality sectors** - companies that exceed medium-sized threshold
- **Qualified trust service providers and top-level domain name registries**, regardless of size
- **DNS service providers**, regardless of size
- Providers of ECN or ECS - medium-sized and large companies

Important entities

- **High criticality sectors** - companies that are small or medium
- **Other critical sectors** - companies that exceed medium-sized threshold
- Providers of ECN or ECS - small companies

■ KEEP IN MIND

■ 1

All entities are required to implement risk management measures.

■ 2

All entities are required to report significant cybersecurity incidents.

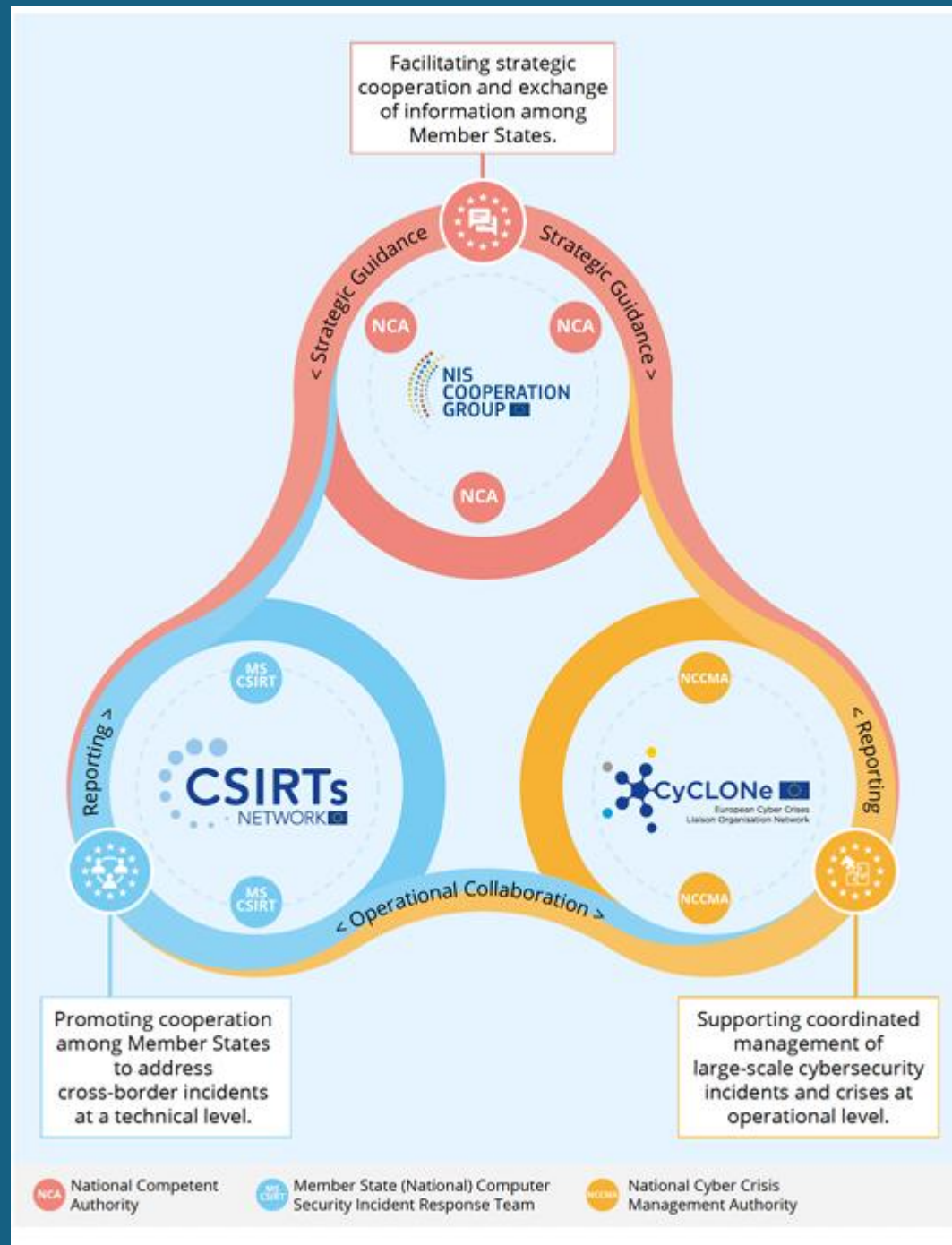
■ 3

Essential entities are subject to ex ante & ex post supervision.

■ 4

Important entities are subject to ex post supervision only.

NIS 2 Directive



Source: ENISA

NIS 2 Directive

■ WHAT IS AN INCIDENT?



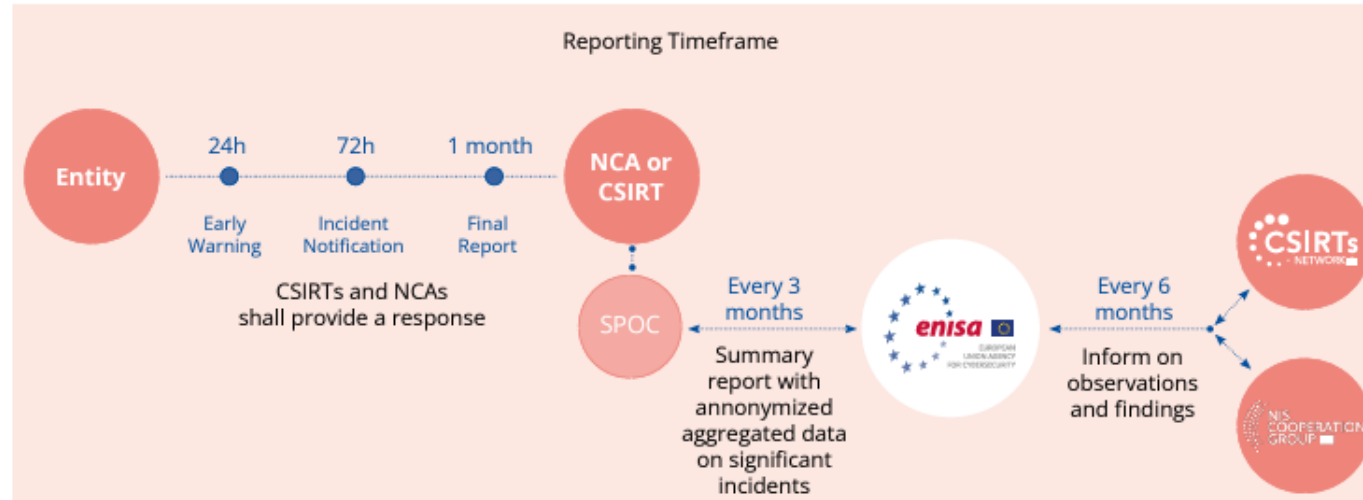
■ WHEN SHOULD I REPORT?

When becoming aware of a **significant incident**:

- | | | | |
|---|---|---|---|
|  | ■ 1
An event that has caused/could cause severe operational disruption or financial loss. |  | ■ 2
An event that has caused or could cause damage to natural or legal persons. |
|---|---|---|---|

NIS 2 Directive

■ A REPORTABLE INCIDENT HAPPENED – NOW WHAT?



■ 1

Where applicable, Member States shall ensure that entities communicate to the recipients of their services that are potentially affected by a significant cyber threat any measures or remedies that those recipients are able to take in response to that threat.

Where appropriate, the entities shall also inform those recipients of the significant cyber threat itself.



■ 2

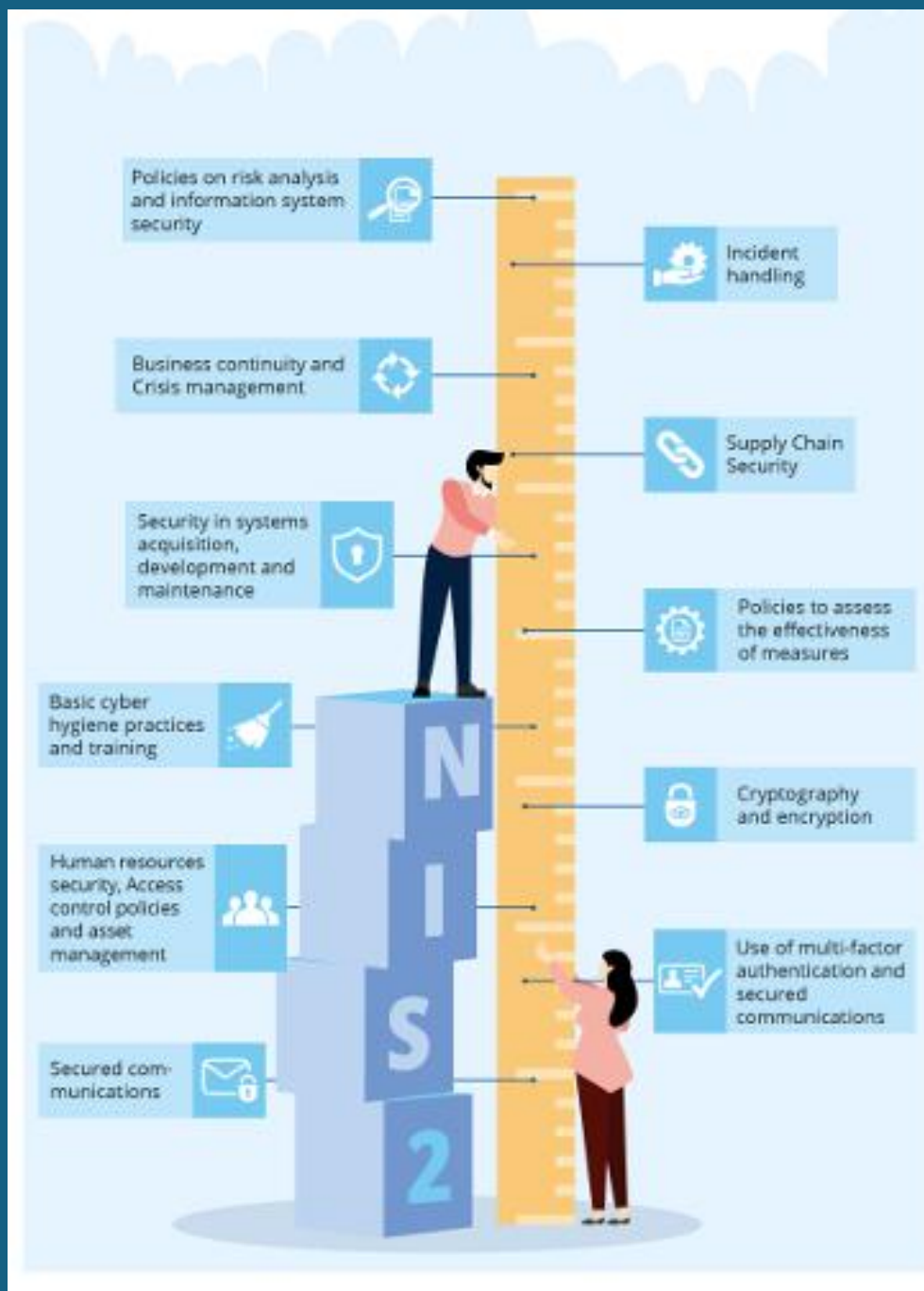
When in the public interest, Member states may inform the public or ask the entity to do so.



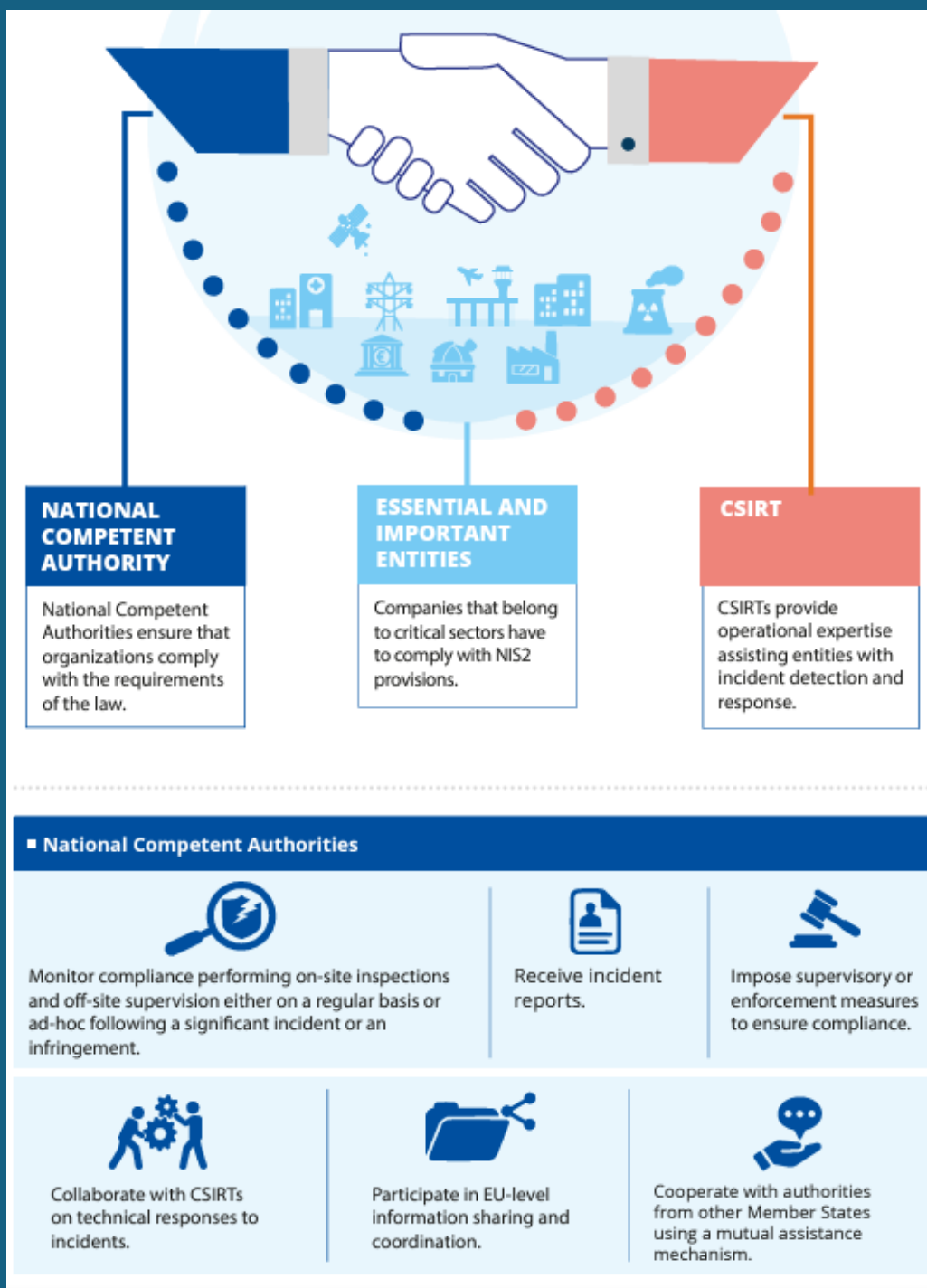
■ 3

If the significant incident concerns two or more Member States, the CSIRT, the competent authority or the single point of contact shall inform, the other affected Member States and ENISA.

NIS 2 Directive



NIS 2 Directive



Source: ENISA

NIS 2 Directive

■ CSIRTs



Detect, analyse and respond to cyber incidents.



Coordinate technical responses to mitigate impact.



Disseminate information about threats and vulnerabilities.



Facilitate EU cooperation and information exchange.



Enhance preparedness and awareness among entities.

■ Essential and Important entities



Implement security measures.



Evidence compliance.



Report significant incidents and on a voluntary basis non-significant incidents and near-misses



The details of supervision depend on national legislation.



Essential entities are subject to a comprehensive ex ante and ex post supervisory regime, while important entities are subject to ex post only, supervisory regime.



Where an entity provides services in more than one Member States, or provides services in one or more Member States and its network and information systems are located in one or more other Member States, the competent authorities of the Member States concerned shall cooperate with and assist each other as necessary, using a mutual assistance mechanism.

NIS 2 Directive

VULNERABILITY DISCLOSURE



NIS2 introduces Coordinated Vulnerability Disclosure, a structured disclosure process and a European database with information about disclosed vulnerabilities.



* The national CVD policy and procedure ensures disclosure is done carefully and timely, so that there is enough time for affected entities to find a patch or a solution, before it is disclosed publicly.

■ 1

A national CVD policy is required by the NIS Directive, to ensure that ethical hackers, who follow good practices, can remain protected from criminal or civil liability and prosecution.



■ 2

The NIS2 designates the national CSIRT as a coordinator between the vendor and ethical hacker, to ensure safe and timely disclosure of new vulnerabilities.

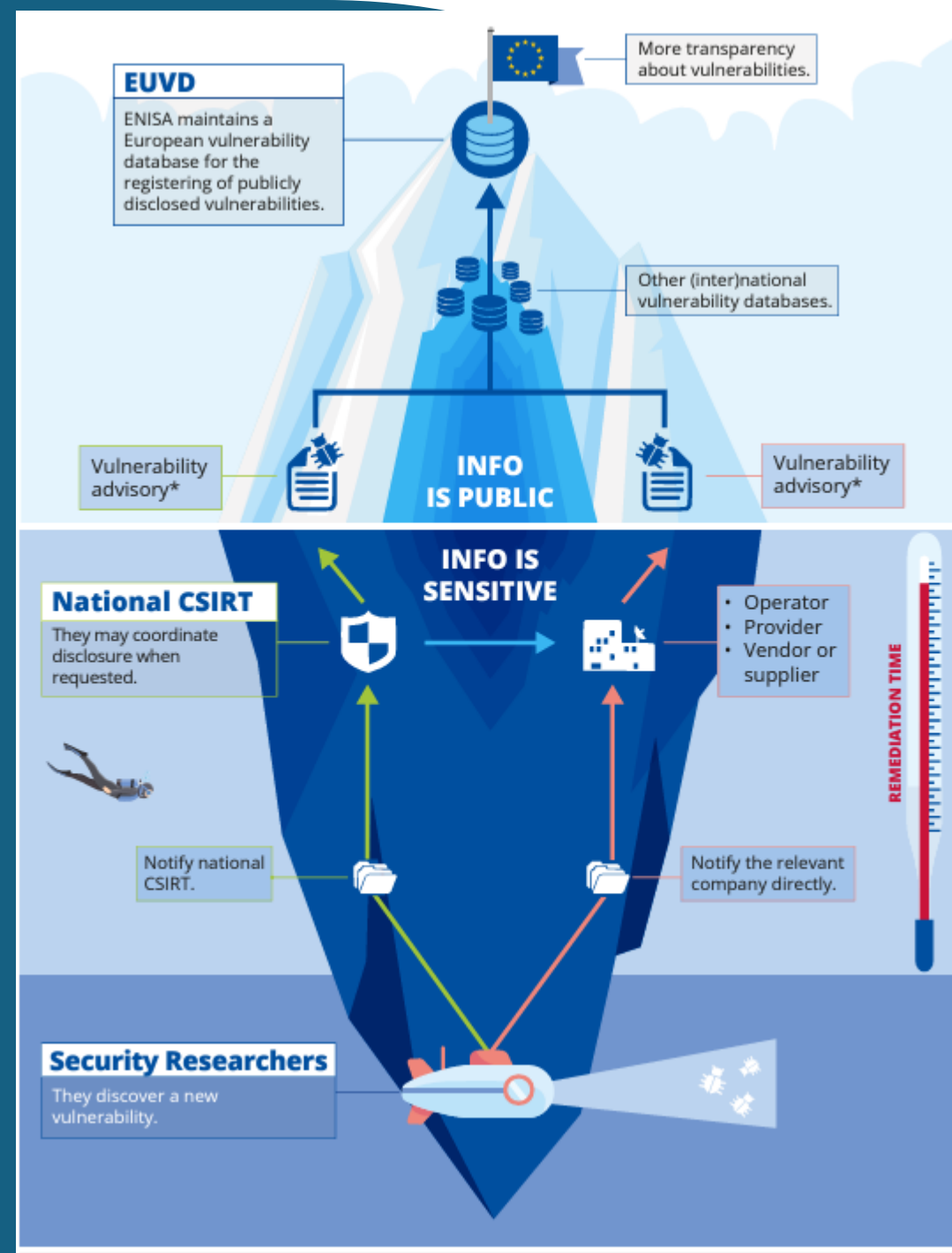


■ 3

For Member States it is important to raise awareness and promote their national CVD policy.



Source: ENISA



NIS 2 Directive

Source: ENISA –
example security measure

3.5 INCIDENT RESPONSE

3.5.1. The relevant entities shall respond to incidents in accordance with documented procedures and in a timely manner.

GUIDANCE

- Establish a dedicated incident response team comprising employees with the necessary technical expertise and authority to respond effectively to incidents.
- Define roles and responsibilities within the incident response team, including incident coordinators, analysts, and communication liaisons.
- Take into account well known standards when developing the incident response procedures¹⁹.

EXAMPLES OF EVIDENCES

- Assignments of roles within the incident response team.
- Documented standards and/or good practices which are taken into account.

3.5.2. The incident response procedures shall include the following stages:

- (a) incident containment, to prevent the consequences of the incident from spreading;
- (b) eradication, to prevent the incident from continuing or reappearing,
- (c) recovery from the incident, where necessary.

GUIDANCE

- Create detailed incident response procedures outlining the steps referred to in point 3.5.2 of the Annex to the Regulation.
- Ensure that the handling of cybersecurity incidents takes into account the entity's priorities and the impact of the incident.
 - Conflicting objectives between:
 - 1) forensic activities to secure evidence,
 - 2) incident response activities to remove existing threats, and
 - 3) objectives of operational IT operations to minimise the impact of the incident,are considered and presented to the management bodies for a decision on how to proceed.

EXAMPLES OF EVIDENCES

- Procedures for incident response, including, types of incidents that could occur, objectives, roles and responsibilities, detailed description, per incident type, how to manage the incident, when to escalate to management bodies (CISO e.g.), etc.
- Records from conflicting objectives resolution during past incidents response.

NIS 2 Directive

3.5.3. The relevant entities shall establish communication plans and procedures:

- (a) with the Computer Security Incident Response Teams (CSIRTs) or, where applicable, the competent authorities, related to incident notification;
- (b) with relevant internal and external stakeholders.

GUIDANCE

- Ensure that the communication plan (3.1.2) includes procedures on how to communicate the incident to relevant authorities and the national CSIRT as well as with the internal and external stakeholders.
- Include contact information for key personnel, external stakeholders, and relevant authorities.

EXAMPLES OF EVIDENCES

- Procedures on how to communicate the incident to relevant authorities and the CSIRT are in place.
- Procedures on how to communicate the incident to customers or how and when to involve a supplier (if applicable).

3.5.4. The relevant entities shall log incident response activities in accordance with the procedures referred to in point 3.2.1., and record evidence.

GUIDANCE

- Log incident response information which at minimum contains (indicative, non-exhaustive list):
 - time of detection, containment and eradication;
 - when the systems recovered;
 - indicators of compromise (IoCs);
 - root cause;
 - actions taken during each phase namely, detection, containment and eradication;
 - impact assessment;
 - communications when responding to the incident;
 - post incident lessons learnt and recommendations; and
 - whether the incident was notified to the CSIRT or the competent authority according to NIS2 articles 23 and 30;

EXAMPLES OF EVIDENCES

- Logs from incident response

Source: ENISA – example security measure

NIS 2 Directive

3.5.5. The relevant entities shall test at planned intervals their incident response procedures.

GUIDANCE

- Test entity's incident response procedures at least annually.
- Test different types of incidents e.g. ransomware, phishing, data breach, DoS, etc.
- Ensure that test scenarios involve employees from different departments as well as external stakeholders e.g. suppliers and service providers.
- Include management bodies in the tests so that they understand their role during an incident.
- Conduct post-test reviews for possible lessons learnt.
- Update the incident response procedures based on the lessons learnt from the test, if applicable.

EXAMPLES OF EVIDENCES

- Documented plans or schedules for future incident response tests.
- Records from tests of different types of incidents.

TIPS

GUIDANCE

- Instructions on how to respond to the most common types of incidents (e.g. ransomware, phishing, data breach, DoS, etc.) including containment, eradication, and recovery steps.
- Include guidelines for preserving evidence and maintaining chain of custody to support forensic analysis and legal proceedings if necessary.
- Consider the use of automated solutions for incident response, e.g. SOAR technologies or similar systems.

EXAMPLES OF EVIDENCES

- Up to date incident response procedures based on test conducted and/or change logs.

Source: ENISA – example security measure

NIS 2 Directive

MAPPING TO STANDARDS & FRAMEWORKS			
European and international frameworks		National Frameworks	
ISO 27001:2022	A.5.26	BE-CyFun®2023	BASIC: RS.RP-1.1
			IMPORTANT: PR.IP-9.1
			ESSENTIAL: PR.IP-9.2, RS.CO-2.2
NIST CSF v2.0	RS.MA-01, RS.MA-02, RS.MA-03, RS.MA-04, ID.IM-02, ID.IM-03, ID.IM-04, RS.CO-02, RS.CO-03, RS.AN-03, RS.MI-01, RS.MI-02, RC.CO-03, RC.CO-04.	FI-Kybermittari	RESPONSE-2, RESPONSE-3
ETSI EN 319 401	REQ-7.9-05, REQ-7.9-09, REQ-7.9-12	EL – Ministerial decision 1027/2019 - Article 4 - paragraph 18	Cybersecurity Handbook: Part B: 17.2, 17.3, 17.4, 17.5, 17.6, 17.9, 17.10
			Self-assessment tool: 18.2, 18.3, 18.4, 18.5, 18.6, 18.7, 18.8
CEN/TS 18026:2024	OIS-03, IM-01, IM-05, IM-07, INQ-02, INQ-03	ES-Royal Decree 311/2022	Article 32, Article 33, Annex II: 4.3.7

Source: ENISA – example security measure

NIS 2 Directive

11.6 AUTHENTICATION

11.6.1. The relevant entities shall implement secure authentication procedures and technologies based on access restrictions and the policy on access control.

GUIDANCE

- Authentication technologies are methods used to verify the identity of users, devices, or systems before granting access to resources. Here are some common authentication technologies (indicative, non-exhaustive list):
 - Password-Based Authentication.
 - Two-Factor Authentication (2FA).
 - Multi-Factor Authentication (MFA).
 - Biometric Authentication.
 - Token-Based Authentication, e.g one-time passcode (OTP).
 - Certificate-Based Authentication.
 - Single Sign-On (SSO).
 - OAuth: An open standard for access delegation, commonly used for token-based authentication and authorization.

EXAMPLES OF EVIDENCES

- Access control policy documents outlining secure authentication procedures and technologies.
- Logs from authentication systems showing successful and failed authentication attempts, which demonstrate secure implementation.
- Evidence of the systems in place that enforce access controls, such as Identity and Access Management (IAM) solutions.
- Internal or external audit reports verifying the implementation of secure authentication procedures aligned with the access control policy.

Source: ENISA – example security measure

NIS 2 Directive

11.6.2. For that purpose, the relevant entities shall:

- (a) ensure the strength of authentication is appropriate to the classification of the asset to be accessed;
- (b) control the allocation to users and management of secret authentication information by a process that ensures the confidentiality of the information, including advising personnel on appropriate handling of authentication information;
- (c) require the change of authentication credentials initially, at predefined intervals and upon suspicion that the credentials were compromised;
- (d) require the reset of authentication credentials and the blocking of users after a predefined number of unsuccessful log-in attempts;
- (e) terminate inactive sessions after a predefined period of inactivity; and
- (f) require separate credentials to access privileged access or administrative accounts.

GUIDANCE

- Use unique authentication credentials for all entity's assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.
- Consider that the allocation and management process of authentication information should ensure that:
 - passwords or PINs generated automatically during enrolment processes as temporary secret authentication information are non-guessable and unique for each user; and that users are required to change them after the first use;
 - procedures are established to verify the identity of a user prior to providing new, replacement or temporary authentication information;
 - authentication information, including temporary authentication information, is transmitted to users in a secure manner (e.g. over an authenticated and protected channel); the use of unprotected (clear text) electronic mail messages is avoided;
 - users acknowledge receipt of authentication information;
 - default authentication information as predefined or provided by suppliers is changed immediately following installation of systems or software;
 - records of significant events concerning allocation and management of authentication information are kept and their confidentiality granted; and that the record -keeping method is approved (e.g. using an approved password vault tool).
- When passwords are used as authentication information, the password management system should:
 - allow users to select and change their own passwords and include a confirmation procedure to address input errors;
 - enforce strong passwords
 - force users to change their passwords at first login;

Source: ENISA –
example security measure

NIS 2 Directive

- enforce password changes as necessary, for example after a security incident, or upon termination or change of employment when a user has known passwords for identities that remain active (e.g. shared identities);
- prevent re-use of previous passwords;
- prevent the use of commonly -used passwords and compromised usernames, password combinations from hacked systems;
- not display passwords on the screen when being entered; and
- store and transmit passwords in protected form.
- Perform password encryption and hashing according to approved cryptographic techniques for passwords.
- Generate an alert when a potential attempted or successful breach of log-on controls is detected.

EXAMPLES OF EVIDENCES

- Logs or reports related to authentication.
- Compliance audits from internal or external audits that verify the management of identities aligns with the policy and regulatory requirements.
- Documentation showing that the identities are reviewed regularly and updated as necessary.
- Records of changes to identities, reflecting any alterations due to role changes or termination of employment.

Source: ENISA – example security measure

NIS 2 Directive

11.6.3. The relevant entities shall to the extent feasible use state-of-the-art authentication methods, in accordance with the associated assessed risk and the classification of the asset to be accessed, and unique authentication information.

GUIDANCE

- Adjust authentication methods based on associated assessed risk. For example, require additional authentication for high-risk transactions or access to assets of higher criticality.
- Use more stringent authentication methods for assets of higher criticality.
- Ensure each user has unique credentials. Avoid shared accounts and implement strict policies for credential management.

EXAMPLES OF EVIDENCES

- Access control policy documents outlining secure authentication procedures and technologies.

11.6.4. The relevant entities shall regularly review the authentication procedures and technologies at planned intervals.

GUIDANCE

- Conduct periodic audits of authentication procedures and technologies to ensure they remain state-of-the-art and effective against emerging threats.
- Stay updated on advancements in authentication technology and integrate new methods as they become available.

EXAMPLES OF EVIDENCES

- Internal or external audit reports detailing the results of periodic audits on authentication procedures and technologies.
- Logs showing the implementation of new authentication technologies and methods as they become available

Source: ENISA – example security measure

NIS 2 Directive

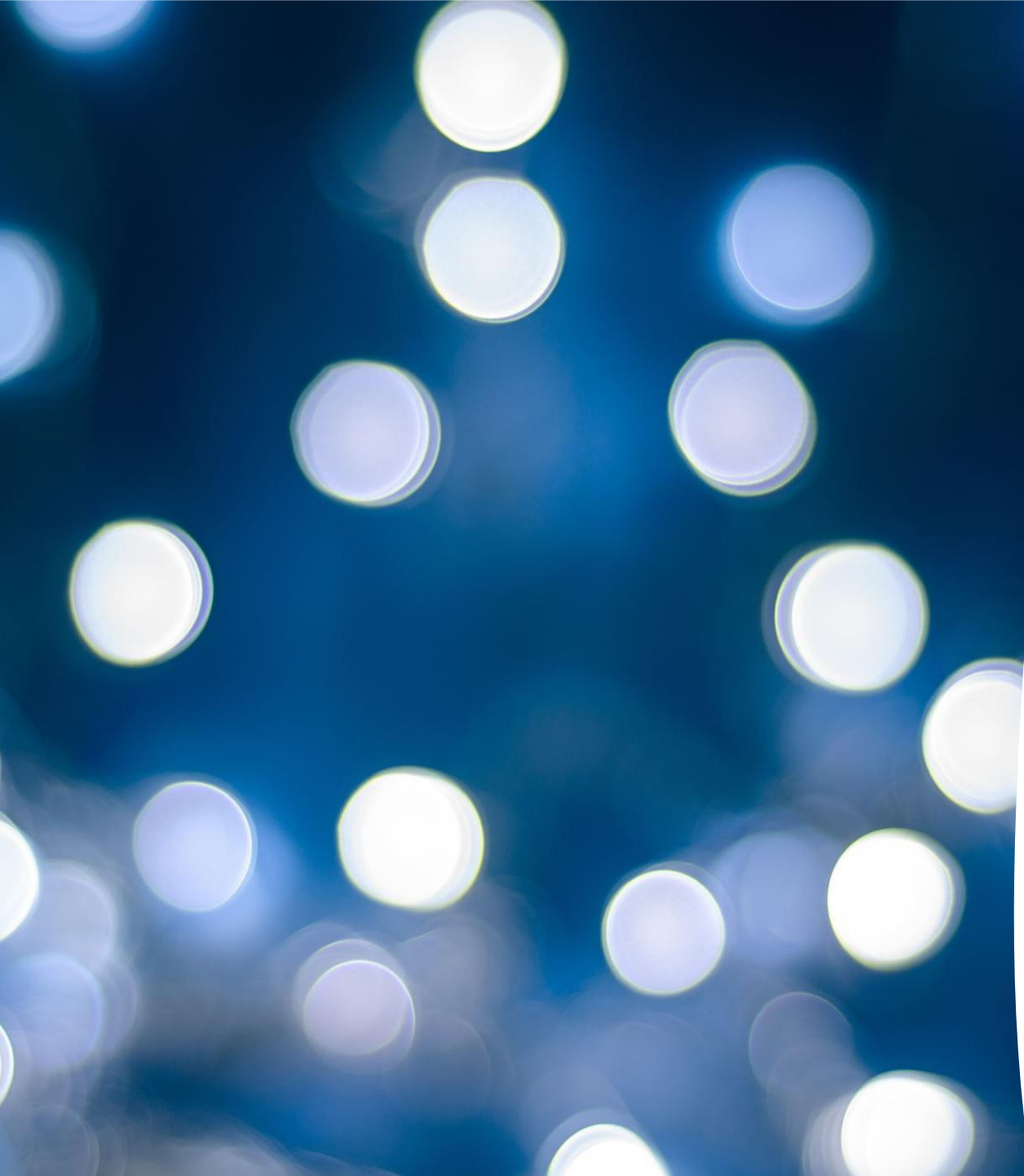
TIPS
GUIDANCE
• Advise any user with access to or using authentication information for the following: ◦ secret authentication information such as passwords are kept confidential. Personal secret authentication information is not to be shared with anyone. Secret authentication information used in the context of identities linked to multiple users or linked to non-personal entities are solely shared with authorized persons; ◦ affected or compromised authentication information is changed immediately upon notification of or any other indication of a compromise; ◦ when passwords are used as authentication information, strong passwords according to best practices recommendations are selected, for example: passwords are not based on anything somebody else can easily guess or obtain using person-related information (e.g. names, telephone numbers and dates of birth); passwords are not based on dictionary words or combinations thereof; use easy to remember passphrases and try to include alphanumeric and special characters; passwords have a minimum length; ◦ the same credentials are not used across distinct network and information systems; and ◦ the obligation to follow these rules are also included in terms and conditions of employment.
EXAMPLES OF EVIDENCES
• Documentation of training sessions for employees on secure authentication practices and technologies. • Records of awareness programs or communications to employees about the importance of secure authentication.

Source: ENISA – example security measure

NIS 2 Directive

MAPPING TO STANDARDS & FRAMEWORKS			
European and international frameworks		National Frameworks	
ISO 27001:2022	A.5.17	BE-CyFun®2023	BASIC: PR.AC-3.2
			IMPORTANT: PR.AC-1.2, PR.AC-1.4, PR.MA-2.2
			ESSENTIAL: PR.AC-6.2
NISTCSF v2.0	PR.AA-05, PR.AA-03, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04	FI-Kybermittari	ACCESS-1, ACCESS-2, ACCESS-3, ACCESS-4, ARCHITECTURE-2, ARCHITECTURE-3, ARCHITECTURE-5
ETSI EN 319 401	REQ-7.4-08	EL – Ministerial decision 1027/2019 - Article 4 - paragraph 8	Cybersecurity Handbook: Part B: 5.1, 5.2, 5.3, 5.4, 5.5, 5.8, 5.10
			Self-assessment tool: 6.1, 6.2, 6.6, 6.7, 6.8, 6.10
CEN/TS 18026:2024	IAM-07, IAM-08	ES-Royal Decree 311/2022	Article 20, Annex II: 4.2.1, 4.2.2, 4.2.3, 4.2.4, 4.2.5, 4.2.6

Source: ENISA – example security measure



Artificial Intelligence Act

The new legal requirements:

- address risks specifically created by AI applications
- prohibit AI practices that pose unacceptable risks
- determine a list of high-risk applications
- set clear requirements for AI systems for high-risk applications
- define specific obligations deployers and providers of high-risk AI applications
- require a conformity assessment before a given AI system is put into service or placed on the market
- put enforcement in place after a given AI system is placed into the market
- establish a governance structure at European and national level

Artificial Intelligence Act

FOCUS AREAS	AI ACT				
ORGANIZATIONS WITHIN SCOPE	Applies to: → Providers, importers and distributors of AI systems or general-purpose AI models that are placed on the EU market, put into service or used in the EU, even if they were established in a third country.				
DEFINITION OF AN AI SYSTEM	A machine-based system designed to operate with varying levels of autonomy that may exhibit adaptiveness after deployment and that, for explicit or implicit objectives, infers from the input it receives, how to generate outputs such as predictions, content, recommendations or decisions that can influence physical or virtual environments.				
RISK LEVELS/ CATEGORIES	Prohibited AI practices	High-risk AI system	General-purpose AI models	General-purpose AI models with systemic risks	Transparency requirements
	A limited set of particularly harmful uses of AI that contravene EU values because they violate fundamental rights. These include: → Social behavioral scoring systems. → Emotion-recognition systems at work and in education. → AI used to exploit people's vulnerabilities, such as their ages or disabilities. → Behavioural manipulation and circumvention of free will. → Untargeted scraping of facial images for facial recognition. → Biometric categorization systems that use certain sensitive characteristics. → Specific predictive policing applications. → Law enforcement use of real-time biometric identification in public, apart from in limited, authorized situations.	AI systems that pose a significant risk to health, safety or fundamental rights, including in the following categories: → Profiling. → Medical devices. → Vehicles. → Emotion-recognition systems. → Law enforcement. → Credit scoring AI systems that are used as a safety component of a product, or are a product themselves, and are regulated by relevant EU sectoral product safety laws.	AI models that display significant generality, are capable of competently performing a wide range of distinct tasks, regardless of how they are placed on the market, and can be integrated into a variety of downstream systems or applications.	General-purpose AI models that have "high-impact capabilities" that match or exceed the capabilities recorded in the most advanced general-purpose AI models. These models must either: → Have high-impact capabilities evaluated against appropriate technical tools, indicators and benchmarks. This is presumed where the cumulative amount of compute used for training is greater than 10^{25} floating point operations. → Be designated as general-purpose AI with systemic risks by the Commission or scientific panel.	Specific transparency obligations are imposed on providers and deployers of certain AI systems. An AI system may be subject to both the transparency requirements and the requirements for high-risk AI systems or general-purpose AI models.

Artificial Intelligence Act

	Prohibited AI practices	High-risk AI system	General-purpose AI models	General-purpose AI models with systemic risks	Transparency requirements
KEY REQUIREMENTS	Such AI systems are prohibited under the AI Act.	These systems require providers to ensure: → Risk management → Data quality and governance. → Documentation and traceability. → Transparency. → Human oversight. → Accuracy, cybersecurity and robustness. → Demonstrated compliance via conformity assessments. → If deployed by public authorities, registration in a public EU database, unless used for law enforcement or migration.	Require providers to: → Perform FRIAs and conformity assessments. → Implement risk management and quality management systems to continually assess and mitigate systemic risks. → Inform individuals when they interact with AI. AI content must be labelled and detectable. → Test and monitor for accuracy, robustness and cybersecurity. General-purpose AI models with systemic risk are subject to greater testing and reporting requirements.	Specific obligations for general-purpose AI models with systemic risks include: → Standardized model evaluation and adversarial testing. → Assessment and mitigation of possible systemic risks. → Documentation of serious incidents and corrective measures. → Adequate level of cybersecurity and physical infrastructure of general-purpose AI models with systemic risks. → Adherence to codes of practice. → Compliance with confidentiality requirements laid under Article 78 for any obtained information or documentation, as well as trade secrets.	Providers of AI systems that interact directly with natural persons must design and develop AI systems to guarantee individual users are aware they are interacting with an AI system. Providers of AI systems that generate synthetic audio, image, video or text content and general-purpose AI systems must ensure outputs are marked in a machine-readable format and detectable as AI generated or manipulated. Deployers of emotion recognition or biometric categorization systems must inform natural persons of the systems' operations. Deployers of AI systems that produce deepfakes or manipulate text meant to inform the public on matters of public interest must abide by disclosure requirements.

Artificial Intelligence Act

SIGNIFICANT PROVISIONS	Transparency. Requirements are imposed on certain AI systems, for example when there is a clear risk of manipulation such as via the use of chatbots. Users should be aware that they are interacting with a machine. Conformity assessments. For AI systems that are safety components of products or are products themselves under listed EU product safety laws, conformity assessments must be performed prior to the systems' placement EU market or when a high-risk AI system is substantially modified. Importers of AI systems must ensure the foreign provider has already carried out the appropriate conformity assessment procedure. FRIAs. Before deployment, public law entity deployers, private operators who provide a public service and private operators who deploy AI systems to evaluate creditworthiness, emergency calls, or risk and pricing for life and health insurance must assess the systems' impact on fundamental rights. If a data protection impact assessment is required, the FRIA should be conducted in conjunction with that DPIA. Generative AI. Providers that generate synthetic audio, image, video or text content must ensure that content is marked in a machine-readable format and is detectable as artificially generated or manipulated.
ENFORCEMENT AND PENALTIES	The AI Office, housed within the European Commission, will supervise AI systems based on general-purpose models when the model and system are provided by the same provider. It will have the powers of a market surveillance authority. National market surveillance authorities are responsible for the supervision of all other AI systems. The AI Office will work to coordinate governance among member countries and supervise enforcement of rules related to general-purpose AI. Member state authorities will lay down rules on penalties and other enforcement measures, including warnings and nonmonetary measures. Individuals can lodge a complaint of infringement with a national competent authority, which can then launch market surveillance activities. The act does not provide for individual damages. There are penalties for: → Prohibited AI violations, up to 7% of global annual turnover or 35 million euros. → Most other violations, up to 3% of global annual turnover or 15 million euros. → Supplying incorrect information to authorities, up to 1% of global annual turnover or 7.5 million euros. The AI Board will advise on the act's implementation, coordinate between national authorities and issue recommendations and opinions.
FURTHER RULEMAKING	The Commission can issue delegated acts on: → Definitions of an AI system. → Criteria and use cases for high-risk AI. → Thresholds for general-purpose AI models with systemic risk. → Technical documentation requirements for general-purpose AI. → Conformity assessments. → EU declarations of conformity. The AI Office is to draw up codes of practice to cover, but not necessarily limited to, obligations for providers of general-purpose AI models. Codes of practice should be ready nine months after the act enters into force at the latest and should provide at least a three-month period before taking effect.



Additional reading material

- Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS 2 Directive)
 - Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)
 - NIS Cooperation Group documents: <https://digital-strategy.ec.europa.eu/en/policies/nis-cooperation-group>
 - NIST Trustworthy and Responsible AI NIST AI 100-2e2023 Adversarial Machine Learning A Taxonomy and Terminology of Attacks and Mitigations
 - NIST Trustworthy and Responsible AI NIST AI 600-1 Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile
 - ENISA, Implementation Guidance on NIS2 security measures
<https://www.enisa.europa.eu/publications/implementation-guidance-on-nis-2-security-measures>
-



DORA (Digital Operational Resilience Act)

About DORA

- Covers a set of industries, including financial services, pension funds,
- 5 Key Pillars:
 - ICT Risk Management
 - Incident Reporting
 - Digital Operational Resilience Testing
 - Management of Third-Party Risk
 - Information Sharing

DORA - Scope

Article 2

Scope

1. Without prejudice to paragraphs 3 and 4, this Regulation applies to the following entities:
 - (a) credit institutions;
 - (b) payment institutions, including payment institutions exempted pursuant to Directive (EU) 2015/2366;
 - (c) account information service providers;
 - (d) electronic money institutions, including electronic money institutions exempted pursuant to Directive 2009/110/EC;
 - (e) investment firms;
 - (f) crypto-asset service providers as authorised under a Regulation of the European Parliament and of the Council on markets in crypto-assets, and amending Regulations (EU) No 1093/2010 and (EU) No 1095/2010 and Directives 2013/36/EU and (EU) 2019/1937 ('the Regulation on markets in crypto-assets') and issuers of asset-referenced tokens;
 - (g) central securities depositories;
 - (h) central counterparties;
 - (i) trading venues;
 - (j) trade repositories;
 - (k) managers of alternative investment funds;
 - (l) management companies;
 - (m) data reporting service providers;
 - (n) insurance and reinsurance undertakings;
 - (o) insurance intermediaries, reinsurance intermediaries and ancillary insurance intermediaries;
 - (p) institutions for occupational retirement provision;
 - (q) credit rating agencies;
 - (r) administrators of critical benchmarks;
 - (s) crowdfunding service providers;
 - (t) securitisation repositories;
 - (u) ICT third-party service providers.

DORA – Sample definitions

- (5) 'ICT risk' means any reasonably identifiable circumstance in relation to the use of network and information systems which, if materialised, may compromise the security of the network and information systems, of any technology dependent tool or process, of operations and processes, or of the provision of services by producing adverse effects in the digital or physical environment;
 - (8) 'ICT-related incident' means a single event or a series of linked events unplanned by the financial entity that compromises the security of the network and information systems, and have an adverse impact on the availability, authenticity, integrity or confidentiality of data, or on the services provided by the financial entity;
- (17) 'threat-led penetration testing (TLPT)' means a framework that mimics the tactics, techniques and procedures of real-life threat actors perceived as posing a genuine cyber threat, that delivers a controlled, bespoke, intelligence-led (red team) test of the financial entity's critical live production systems;
 - (18) 'ICT third-party risk' means an ICT risk that may arise for a financial entity in relation to its use of ICT services provided by ICT third-party service providers or by subcontractors of the latter, including through outsourcing arrangements;
- (15) 'threat intelligence' means information that has been aggregated, transformed, analysed, interpreted or enriched to provide the necessary context for decision-making and to enable relevant and sufficient understanding in order to mitigate the impact of an ICT-related incident or of a cyber threat, including the technical details of a cyber-attack, those responsible for the attack and their modus operandi and motivations;
 - (16) 'vulnerability' means a weakness, susceptibility or flaw of an asset, system, process or control that can be exploited;

DORA – Role of the management

- Article 5 of DORA – except and some key points
 - Strategy
 - Setting roles and responsibilities
 - Oversee implementation
 - Monitor
 - Ensure proper budget

2. The management body of the financial entity shall define, approve, oversee and be responsible for the implementation of all arrangements related to the ICT risk management framework referred to in Article 6(1).

For the purposes of the first subparagraph, the management body shall:

- (a) bear the ultimate responsibility for managing the financial entity's ICT risk;
- (b) put in place policies that aim to ensure the maintenance of high standards of availability, authenticity, integrity and confidentiality, of data;
- (c) set clear roles and responsibilities for all ICT-related functions and establish appropriate governance arrangements to ensure effective and timely communication, cooperation and coordination among those functions;
- (d) bear the overall responsibility for setting and approving the digital operational resilience strategy as referred to in Article 6(8), including the determination of the appropriate risk tolerance level of ICT risk of the financial entity, as referred to in Article 6(8), point (b);
- (e) approve, oversee and periodically review the implementation of the financial entity's ICT business continuity policy and ICT response and recovery plans, referred to, respectively, in Article 11(1) and (3), which may be adopted as a dedicated specific policy forming an integral part of the financial entity's overall business continuity policy and response and recovery plan;
- (f) approve and periodically review the financial entity's ICT internal audit plans, ICT audits and material modifications to them;
- (g) allocate and periodically review the appropriate budget to fulfil the financial entity's digital operational resilience needs in respect of all types of resources, including relevant ICT security awareness programmes and digital operational resilience training referred to in Article 13(6), and ICT skills for all staff;
- (h) approve and periodically review the financial entity's policy on arrangements regarding the use of ICT services provided by ICT third-party service providers;
- (i) put in place, at corporate level, reporting channels enabling it to be duly informed of the following:
 - (i) arrangements concluded with ICT third-party service providers on the use of ICT services,
 - (ii) any relevant planned material changes regarding the ICT third-party service providers,
 - (iii) the potential impact of such changes on the critical or important functions subject to those arrangements, including a risk analysis summary to assess the impact of those changes, and at least major ICT-related incidents and their impact, as well as response, recovery and corrective measures.

DORA - Outline

- ICT Risk management

The management of a financial entity must define, approve, oversee, and be accountable for the implementation of all aspects concerning ICT risk management framework

Management should link the business strategy to the resilience strategy, with an agreed set of critical business functions and which assets are critical/important for their proper functioning.

- Incident reporting

Entities must establish and implement an ICT-related incident management process to detect, manage, and notify ICT-related incidents and to put in place early warning indicators as alerts

Entities must design a classification framework for incident management, which should be consistent throughout any typology of incident.

DORA - Outline

- Digital Operational Resilience Testing

Entities have to set in place a comprehensive testing program that includes a wide variety of tests limited not just to IT assets, but also on processes and people (to discuss correlation with TIBER).

The exhaustive testing framework should be governed through a risk-based approach, while having in mind service criticality classification of such process or IT asset.

- Management of Third-Party Risk

Entities must manage ICT third-party risk within their ICT risk management process.

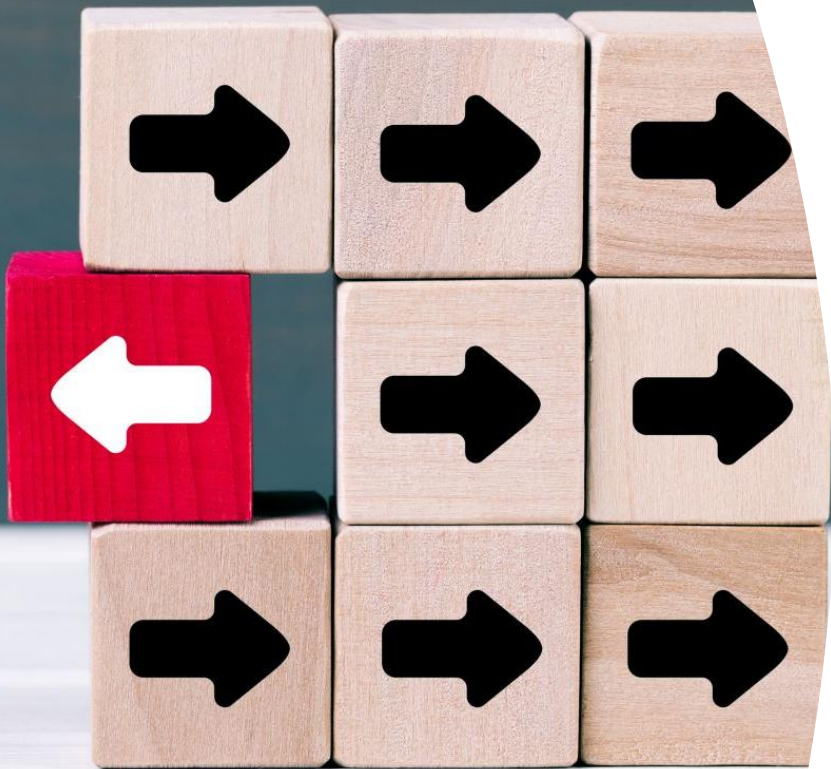
Adequate due diligence of third party providers and proper contractual agreements that clearly set out rights and obligations as per legal requirements.

- Information Sharing

Entities may exchange among themselves cyber threat information and intelligence, including indicators of compromise, tactics, techniques, and procedures, cyber security alerts, and configuration tools.

Concept – critical or important functions

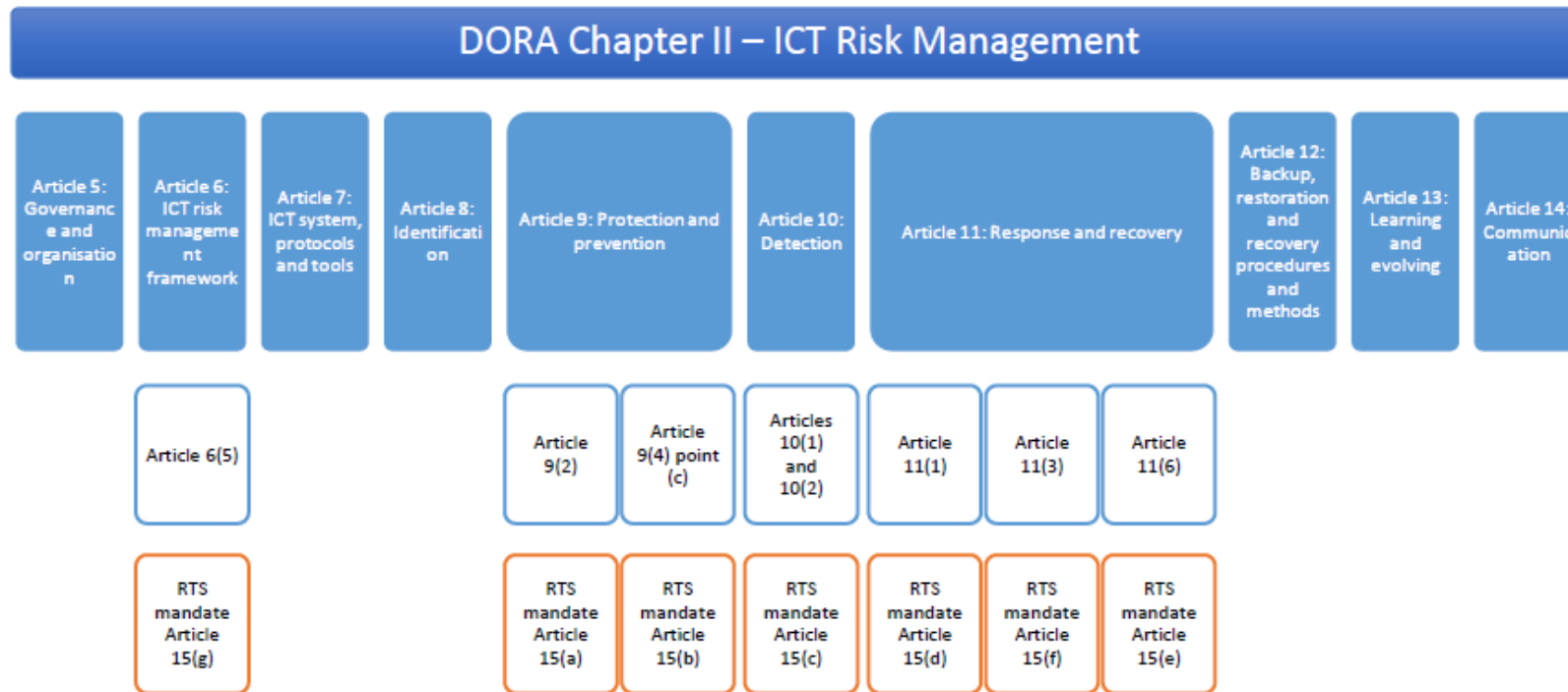
- means a function,
 - the **disruption** of which => would materially impair the **financial performance** of a financial entity,
 - or the soundness or continuity of its services and activities, or the **discontinued, defective or failed performance** of that function => would materially impair the continuing **compliance** of a financial entity with the conditions and obligations of its **authorisation**, or with its other obligations under applicable financial services **law**;



ICT Risk management

- DORA provisions
- RTS provisions

ICT Risk management



ICT Risk management

- Article 3 of the RTS on ICT Risk management

- (a) the indication of the approval of the risk tolerance level for ICT risk established according to Article 6(8), point (b), of Regulation (EU) 2022/2554;
- (b) the procedure and the methodology to conduct the ICT risk assessment, identifying vulnerabilities and threats that affect or may affect the supported business functions, the ICT systems and ICT assets supporting those functions and the quantitative or qualitative indicators to measure impact and likelihood of those vulnerabilities being exploited by threats;
- (c) the procedure to identify, implement and document ICT risk treatment measures for the ICT risk assessed, including the determination of ICT risk treatment measures necessary to bring ICT risk within the risk tolerance levels referred to in point (a). The procedure shall ensure the monitoring of the effectiveness of the measures implemented, the assessment of whether the established risk tolerance levels of the financial entity have been attained and that the financial entity takes actions to correct or improve the measures where necessary;
- (d) with reference to the ICT risk that is still present following the implementation of the ICT risk treatment measures:
 - (i) provisions on the identification of residual ICT risks;
 - (ii) the assignment of roles and responsibilities regarding the acceptance of the residual ICT risks that exceed the financial entity's risk tolerance level referred to in point (a), and for the assessment process referred to in point (iv);
 - (iii) the development of an inventory of the accepted residual ICT risks, including an explanation of the reasons for which they were accepted;
 - (iv) provisions on the assessment of the accepted residual ICT risks at least once a year, including the identification of any changes to the residual ICT risks, the assessment of available mitigation measures and the assessment of whether the reasons justifying the acceptance of residual ICT risks are still valid and applicable at the date of the review;
- (e) provisions on the monitoring of any changes to the ICT risk and cyber threat landscape, internal and external vulnerabilities and threats and of ICT risk of the financial entity to promptly detect changes that could affect its ICT risk profile;

DORA – ICT Risk Management

Certain key points from DORA Article 7

strategy

policy, procedure

ICT risk overseen by a control function (2nd line of defence) - segregation and independence

ICT risk management framework reviewed at least once a year

KPIs (key performance indicators) and KRIs (Key risk indicators)

Article 8 of DORA - Identification

Identify, classify and document ICT business functions and ICT assets and information assets supporting those functions

Identify risk exposure through identification of threats and vulnerabilities

Perform risk assessment after each major change in network and information system infrastructure

Monitor changes in the ICT landscape

Update regularly inventories

Article 9 of DORA - Protection and prevention

security at all levels of the OSI model through policies, implementation of controls and monitoring

vulnerability management

security by design in change management

implement risk-based approach

DORA – ICT Risk Management

Article 10 of DORA - Detection

detection of anomalous activities

sufficient resources and capabilities for
incident response process

lessons learnt process

Article 11 - Response and recovery

ensure continuity of critical or important
functions

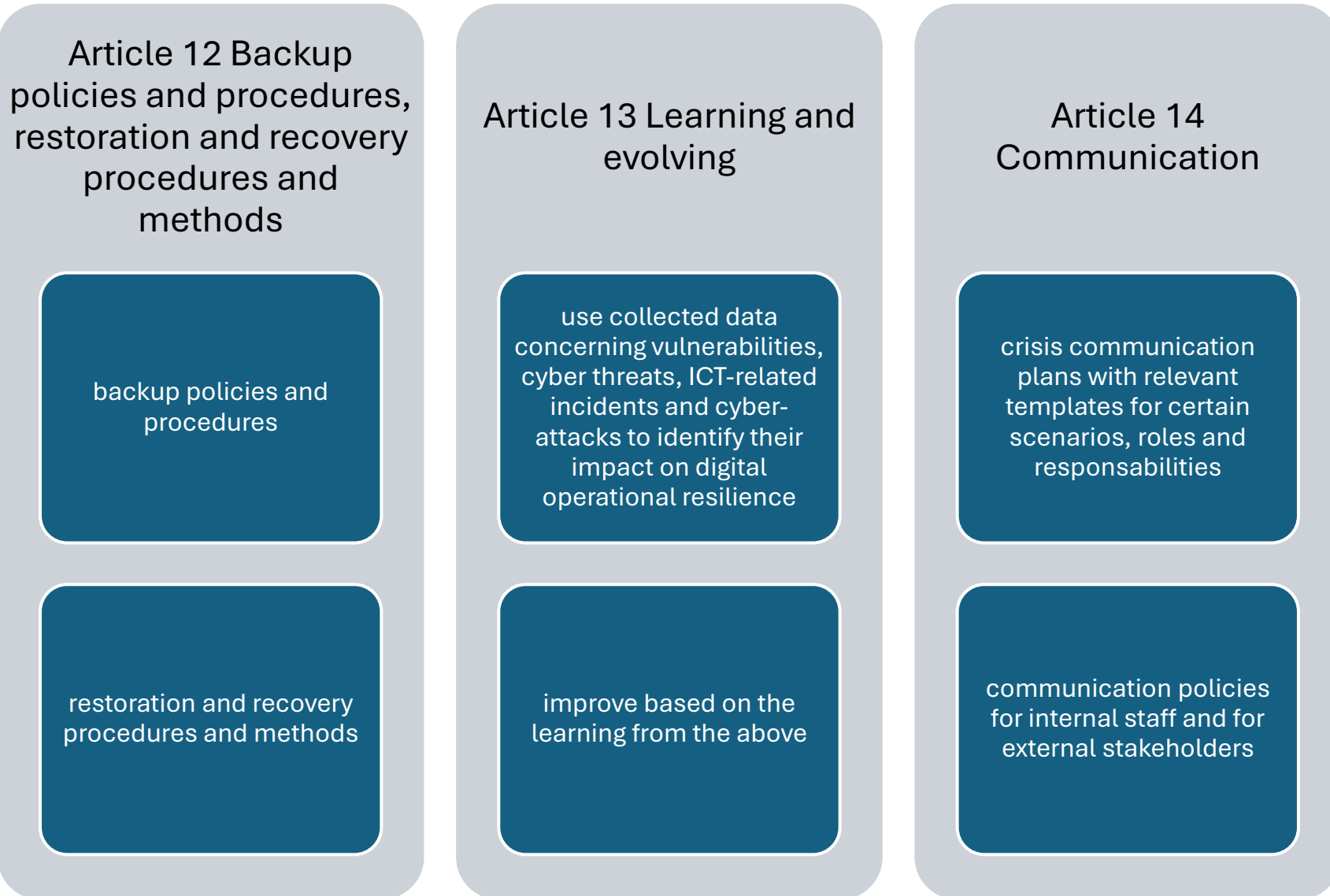
quickly, appropriately and effectively
respond to and resolve ICT related
incidents

estimate impacts, damages, losses

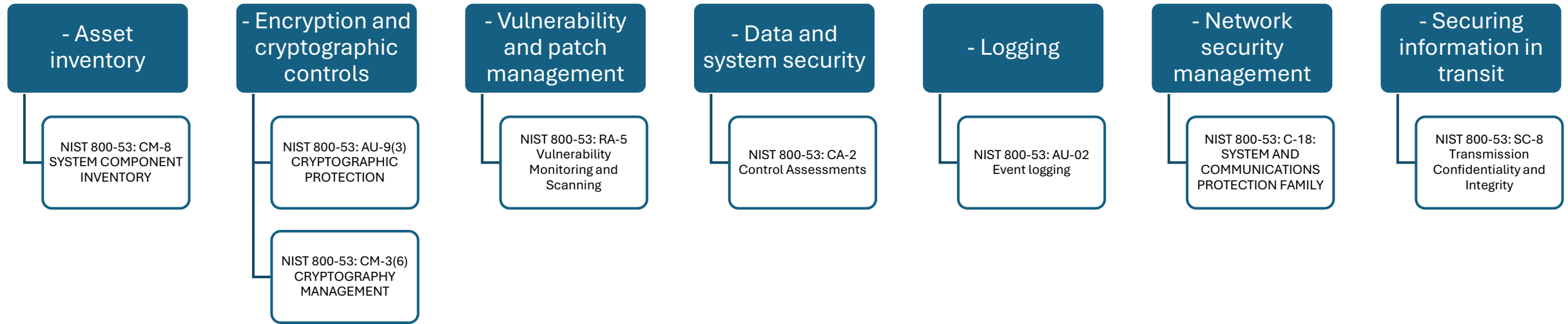
crisis management and communication

test business continuity plans and crisis
communication plans

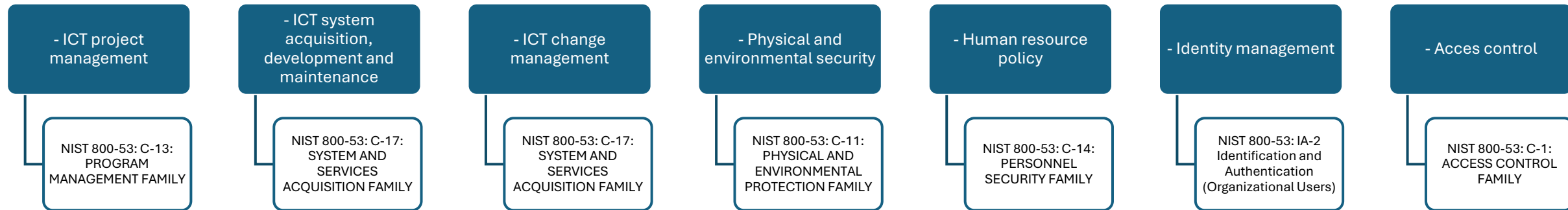
DORA – ICT Risk Management



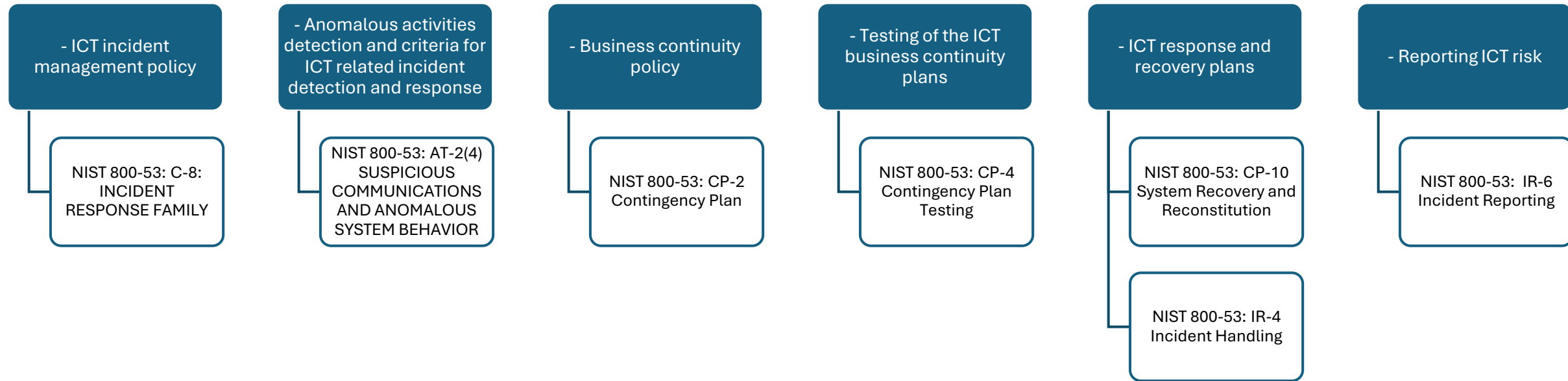
DORA – RTS ICT Risk Management – main areas covered



DORA – RTS ICT Risk Management – main areas covered



DORA – RTS ICT Risk Management – main areas covered



Examples RTS requirements for ICT risk management

Article 8

Policies and procedures for ICT operations

1. As part of the ICT security policies and procedures, financial entities shall develop, document and implement policies and procedures to manage the ICT operations of ICT assets, with a view to ensuring the security of networks, enabling adequate safeguards against intrusions and data misuse and preserving the availability, authenticity, integrity and confidentiality of data. These policies and procedures shall define how financial entities operate, monitor, control and restore their ICT assets, including the documentation of ICT operations.
2. The policies and procedures for ICT operations referred to in paragraph 1 shall include all of the following elements:
 - (a) ICT assets description, including all of the following:
 - (i) secure installation, maintenance, configuration and deinstallation of ICT systems;
 - (ii) management of information assets used by ICT assets, including their processing and handling, automated and manual;
 - (iii) identification and control of legacy ICT systems;
 - (b) controls and monitoring of ICT systems, including all of the following:
 - (i) backup and restoration requirements of ICT systems;
 - (ii) scheduling requirements, taking into consideration interdependencies among the ICT systems;
 - (iii) protocols for audit-trail and system log information;

Examples RTS requirements for ICT risk management

- (iv) requirements to ensure that the performance of internal audit and other testing minimises disruptions to business operations;
 - (v) requirements on the separation of ICT production environments from the development, testing and other non-production environments. The separation shall consider all of the components of the environment, such as accounts, data or connections;
 - (vi) requirements to conduct the development and testing in environments which are separated from the production environment;
 - (vii) requirements to conduct the development and testing in production environments. The policies and procedures shall provide that the instances in which testing is performed in production environment are clearly identified, justified, for limited periods of time approved by the relevant function, and considering Article 16(6). The availability, confidentiality, integrity and authenticity of ICT systems and production data shall be ensured during development and test activities in production environment;
- (c) error handling concerning ICT systems, including all of the following:
- (i) procedures and protocols for handling errors;
 - (ii) support and escalation contacts, including external support contacts in case of unexpected operational or technical issues;
 - (iii) ICT system restart, rollback and recovery procedures for use in the event of ICT system disruption.

DORA – Reporting ICT risk

CHAPTER V

REPORT ON THE ICT RISK MANAGEMENT FRAMEWORK REVIEW

Article 27

Format and content

1. Financial entities shall develop and document the report referred to in Article 6(5) of Regulation (EU) 2022/2554 in a searchable electronic format.
2. Financial entities shall include all of the following information in the report:
 - (a) an introductory section which:
 - (i) clearly identifies the financial entity, the subject of the report and describes its group structure, where relevant;
 - (ii) describes the context of the report in terms of the nature, scale and complexity of the financial entity's services, activities and operations, its organisation, identified critical functions, strategy, major ongoing projects or activities, relationships and its dependence on in-house and contracted ICT services and systems or the implications that a total loss or severe degradation of such systems would have in terms of critical or important functions and market efficiency;
 - (iii) summarises the major changes in the ICT risk management framework since the previous report;
 - (iv) provides an executive level summary of the current and near-term ICT risk profile, threat landscape, the assessed effectiveness of its controls and the security posture of the financial entity;
 - (b) date of the approval of the report by the management body of the financial entity;
 - (c) description of the reason for the review of the ICT risk management framework in accordance with Article 6(5) of Regulation (EU) 2022/2554. Where the review was initiated following supervisory instructions or conclusions derived from relevant digital operational resilience testing or audit processes, the report shall contain explicit references to such documents or instructions, allowing for the identification of the reason for initiating the review. Where the review was initiated following ICT-related incidents, the report shall contain the list of all ICT-related incidents with incident root-cause analysis;
 - (d) start and end dates of the review period;
 - (e) indication of the function responsible for the review;
 - (f) description of the major changes and improvements to the ICT risk management framework since the previous review. This description shall include an analysis of the impact of the changes on the financial entity's digital operational resilience strategy, on the financial entity's ICT internal control framework and on the financial entity's ICT risk management governance;
 - (g) summary of the findings of the review and detailed analysis and assessment of the severity of the weaknesses, deficiencies and gaps in the ICT risk management framework during the review period;
 - (h) description of the measures to address identified weaknesses, deficiencies and gaps, including all of the following:
 - (i) summary of measures taken to remediate to identified weaknesses, deficiencies and gaps;
 - (ii) expected date for implementing the measures and dates related to the internal control of the implementation, including information on the state of progress of their implementation as at the date of drafting of the report, explaining, where applicable, if there is a risk that deadlines may not be respected;
 - (iii) tools to be used and identification of the function responsible for carrying out the measures, detailing whether they are internal or external;
 - (iv) description of the impact of the changes envisaged in the measures on the financial entity's budgetary, human and material resources, including resources dedicated to the implementation of corrective measures;
 - (v) information on the process for informing the competent authority, where appropriate;
 - (vi) if the weaknesses, deficiencies or gaps identified are not subject to remedial measures, a detailed explanation of the criteria used to analyse their impact, to evaluate the related residual risk and for the acceptance of such a risk;
 - (i) information on planned further developments;
 - (j) conclusions resulting from the review of the ICT risk management framework;
 - (k) information on past reviews:
 - (i) list of past reviews to date;
 - (ii) if applicable, state of implementation of the mitigation measures identified by the last report;

DORA – Reporting ICT risk

- Note: Simplified version of ICT risk management framework for certain entities, according to article 16(1) of DORA

(iii) where applicable, description of whether the proposed remedying measures in past reviews have proven ineffective or created unexpected challenges, and how they could be improved;

(l) sources of information used in the preparation of the report, including at least all of the following:

- (i) for financial entities referred to in Article 6(6), of Regulation (EU) 2022/2554, results from internal audit;
- (ii) results from compliance assessments;
- (iii) results from digital operational resilience testing and, where applicable, advanced testing of ICT tools, systems and processes based on TLPT;
- (iv) external sources.

- Detect ICT incidents
- Manage ICT incidents
- Notify ICT incidents

ICT-related incidents

3. The ICT-related incident management process referred to in paragraph 1 shall:
 - (a) put in place early warning indicators;
 - (b) establish procedures to identify, track, log, categorise and classify ICT-related incidents according to their priority and severity and according to the criticality of the services impacted, in accordance with the criteria set out in Article 18(1);
 - (c) assign roles and responsibilities that need to be activated for different ICT-related incident types and scenarios;
 - (d) set out plans for communication to staff, external stakeholders and media in accordance with Article 14 and for notification to clients, for internal escalation procedures, including ICT-related customer complaints, as well as for the provision of information to financial entities that act as counterparts, as appropriate;
 - (e) ensure that at least major ICT-related incidents are reported to relevant senior management and inform the management body of at least major ICT-related incidents, explaining the impact, response and additional controls to be established as a result of such ICT-related incidents;
 - (f) establish ICT-related incident response procedures to mitigate impacts and ensure that services become operational and secure in a timely manner.

ICT-related incidents

DORA Regulation

Article 18

Classification of ICT-related incidents and cyber threats

1. Financial entities shall classify ICT-related incidents and shall determine their impact based on the following criteria:
 - (a) the number and/or relevance of clients or financial counterparts affected and, where applicable, the amount or number of transactions affected by the ICT-related incident, and whether the ICT-related incident has caused reputational impact;
 - (b) the duration of the ICT-related incident, including the service downtime;
 - (c) the geographical spread with regard to the areas affected by the ICT-related incident, particularly if it affects more than two Member States;
 - (d) the data losses that the ICT-related incident entails, in relation to availability, authenticity, integrity or confidentiality of data;
 - (e) the criticality of the services affected, including the financial entity's transactions and operations;
 - (f) the economic impact, in particular direct and indirect costs and losses, of the ICT-related incident in both absolute and relative terms.

ICT-related incidents

Draft Regulatory Technical Standards

on the content of the notification and reports for major incidents and significant cyber threats and determining the time limits for reporting major incidents

Table 1: Overview of the classification criteria and their thresholds for major incidents under DORA as introduced in the final draft RTS

Major ICT-related Incident or security or operational payment-related incident							
if critical services are affected and (i) <u>any malicious unauthorised access to network and information systems identified, which may result to data losses</u> or (ii) the thresholds of two additional criteria from the below are met							
	Mandatory condition	Additional classification criteria					
	Critical services affected	Clients, financial counterparts and transactions	Data losses	Reputational Impact	Duration and Service Downtime	Geographical Spread	Economic Impact
Materiality threshold	The incident has had any impact on critical services	Any of: a) >10% of all clients using the affected service; b) >100 000 clients using the affected service; c) >30% of all financial counterparts used by the FE; d) >10% of the daily average number of transactions; e) >10% of the daily average amount of transactions; f) any identified impact on clients or financial counterpart identified by the FE as relevant.	Any impact on the availability, authenticity, integrity or confidentiality of data, which has or will have an adverse impact on the implementation of the business objectives of the FE or on meeting regulatory requirements	Any reputational impact set out in Article 2 a) to d) (overview below)	a) incident duration is longer than 24 hours; or b) service downtime is longer than 2 hours for ICT services that support critical or important functions	Any impact of the incident identified in the territories of at least two Member States	Costs and losses incurred by the FE exceed or are likely to exceed €100 000 (can be based on estimates where actuals cannot be determined)
Criteria Detail	Assess if the incident : a) affects ICT services or Network and information systems that support critical or important functions of the FE; or b) affects financial services that require authorisation, registration or are otherwise supervised by competent authorities; or c) represents a successful, malicious and unauthorised access to the network and information systems of the financial entity.	1. all affected clients unable to make use of the service provided by the FE during the incident or that were adversely impacted by the incident. These include also third parties explicitly covered by the contractual agreement between the FE and the client as beneficiaries of the affected service. 2. all affected financial counterparts with contractual arrangements with the FE. 3. relevant clients and financial counterparts whose impact will affect the business objectives of the FE or market efficiency. 4. all affected transactions with monetary amount, with one leg in the EU. (FEs can use estimates from comparable reference periods where actuals not available)	1. availability of data – data on demand rendered temporarily or permanently inaccessible or unusable; 2. authenticity of data – compromised trustworthiness of the source of data; 3. integrity of data – data inaccurate or incomplete due to non-authorised modification 4. confidentiality of data – data being accessed by or disclosed to unauthorised party or system.	Reputational impact evidenced by any of the below: a) incident reflected in the media; or b) received repetitive complaints; or c) inability to meet regulatory requirements; or d) likely loss of clients or financial counterparts with a material impact on FE's business. Level of visibility of the incident to be taken into account.	1. Duration measured from the moment an incident occurs or is detected, until it is resolved. (estimate if not yet known) 2. Service downtime measured from the moment service fully/partially unavailable/delayed to clients, financial counterparts or other internal or external users, until activities are restored to the same level before the incident.	Assess significant impact of the incident in other EU Member States on: a) clients or financial counterparts; b) branches of the FE or other group financial entities; (c) Financial market infrastructures or third party providers that may affect other FEs.	Types of direct and indirect incurred costs a) expropriated funds or financial assets liability, including theft; b) replacement or relocation costs; c) staff costs; d) contract non-compliance fees; e) customer redress and compensation costs; f) forgone revenues; g) communication costs; h) advisory costs. (based on available data at time of reporting)
Triggered Yes/No							

ICT-related incidents

DORA Regulation

Article 19 - Reporting

4. Financial entities shall, within the time limits to be laid down in accordance with Article 20, first paragraph, point (a), point (ii), submit the following to the relevant competent authority:

- (a) an initial notification;
- (b) an intermediate report after the initial notification referred to in point (a), as soon as the status of the original incident has changed significantly or the handling of the major ICT-related incident has changed based on new information available, followed, as appropriate, by updated notifications every time a relevant status update is available, as well as upon a specific request of the competent authority;
- (c) a final report, when the root cause analysis has been completed, regardless of whether mitigation measures have already been implemented, and when the actual impact figures are available to replace estimates.

ICT-related incidents

Draft Regulatory Technical Standards

on the content of the notification and reports for major incidents and significant cyber threats and determining the time limits for reporting major incidents

Article 3 *Content of initial notifications*

Financial entities shall provide at least the following information about the incident in the initial notification:

- a) incident reference code
- b) date and time of detection and classification of the incident;
- c) description of the incident;
- d) classification criteria that triggered the incident report as set out in [Articles 1 to 8 of Delegated Regulation [insert number once published in official journal]];
- e) members States impacted by the incident, where applicable;
- f) information on how the incident has been discovered;
- g) information about the origin of the incident, where available;
- h) indication whether a business continuity plan has been activated;
- i) information about the reclassification of the incident from major to non-major, where applicable; and
- j) other information, where available.

Article 4 *Content of intermediate reports*

Financial entities shall provide at least the following information about the incident in the intermediate report:

- a) incident reference code provided by the competent authority, where applicable;
- b) date and time of occurrence of the incident;
- c) date and time when regular activities have been restored, where applicable;
- d) information about the classification criteria that triggered the incident report;
- e) type of the incident;
- f) threats and techniques used by the threat actor, where applicable;
- g) affected functional areas and business processes;
- h) affected infrastructure components supporting business processes;
- i) impact on the financial interest of clients;
- j) information about reporting to other authorities;
- k) temporary actions/measures taken or planned to be taken to recover from the incident; and
- l) information on indicators of compromise, where applicable.

Article 5 *Content of final reports*

Financial entities shall provide the following information about the incident in the final report:

- a) information about the root causes of the incident
- b) dates and times when the incident was resolved and the root cause addressed;
- c) information on the incident resolution;
- d) information relevant for resolution authorities, where applicable;
- e) information about direct and indirect costs and losses stemming from the incident and information about financial recoveries; and
- f) information about recurring incidents, where applicable.

Digital operational resilience testing

DORA Regulation

Article 25

Testing of ICT tools and systems

1. The digital operational resilience testing programme referred to in Article 24 shall provide, in accordance with the criteria set out in Article 4(2), for the execution of appropriate tests, such as vulnerability assessments and scans, open source analyses, network security assessments, gap analyses, physical security reviews, questionnaires and scanning software solutions, source code reviews where feasible, scenario-based tests, compatibility testing, performance testing, end-to-end testing and penetration testing.

8. Financial entities shall contract testers for the purposes of undertaking TLPT in accordance with Article 27. When financial entities use internal testers for the purposes of undertaking TLPT, they shall contract external testers every three tests.

Article 27

Requirements for testers for the carrying out of TLPT

1. Financial entities shall only use testers for the carrying out of TLPT, that:
 - (a) are of the highest suitability and reputability;
 - (b) possess technical and organisational capabilities and demonstrate specific expertise in threat intelligence, penetration testing and red team testing;
 - (c) are certified by an accreditation body in a Member State or adhere to formal codes of conduct or ethical frameworks;
 - (d) provide an independent assurance, or an audit report, in relation to the sound management of risks associated with the carrying out of TLPT, including the due protection of the financial entity's confidential information and redress for the business risks of the financial entity;
 - (e) are duly and fully covered by relevant professional indemnity insurances, including against risks of misconduct and negligence.
2. When using internal testers, financial entities shall ensure that, in addition to the requirements in paragraph 1, the following conditions are met:
 - (a) such use has been approved by the relevant competent authority or by the single public authority designated in accordance with Article 26(9) and (10);
 - (b) the relevant competent authority has verified that the financial entity has sufficient dedicated resources and ensured that conflicts of interest are avoided throughout the design and execution phases of the test; and
 - (c) the threat intelligence provider is external to the financial entity.

Digital operational resilience testing

40. The main stakeholders in a TLPT are:

- The **TLPT cyber team** (or TCT) mirrors the TIBER cyber team in the TIBER-EU framework. It is the staff within the TLPT authority where all operative TLPT-related matters are addressed. For example, it may be comprised of the test managers;
- The **control team** mirrors the white team under the TIBER-EU framework and manages the TLPT from the side of the financial entity undergoing the exercise. This includes all aspects from procurement of the external providers, the risk assessment the operational management of the day-to-day testing activities, risk management, etc. The control team lead should have the necessary mandate within the financial entity to guide all the aspects of the test, without compromising the secrecy of the test;
- The **blue team** is, similarly to the TIBER-EU framework, made up of those employees that are defending the financial entity against simulated or real cyber threat while not knowing that they are tested;
- The **threat intelligence provider**, similar to the TIBER-EU framework concept, mimics an hacker information gathering activity by using multiple reliable sources;
- DORA concept of '**testers**' is broader than that of 'red team' under the TIBER-EU framework as DORA permits the use of both internal and external testers. Tested entities may use both types of testers as long as all requirements are complied with. Part of the ESA's mandate was to develop specific requirements applying to the use of internal testers (please see section 3.6 below).

Article 26

11

Scope of TLPT: several or all critical or important functions - production environment

3rd parties: if services/applications provided by third parties are in scope, the 3rd parties should participate

Reporting to DORA authority: summary of findings and remediation plans

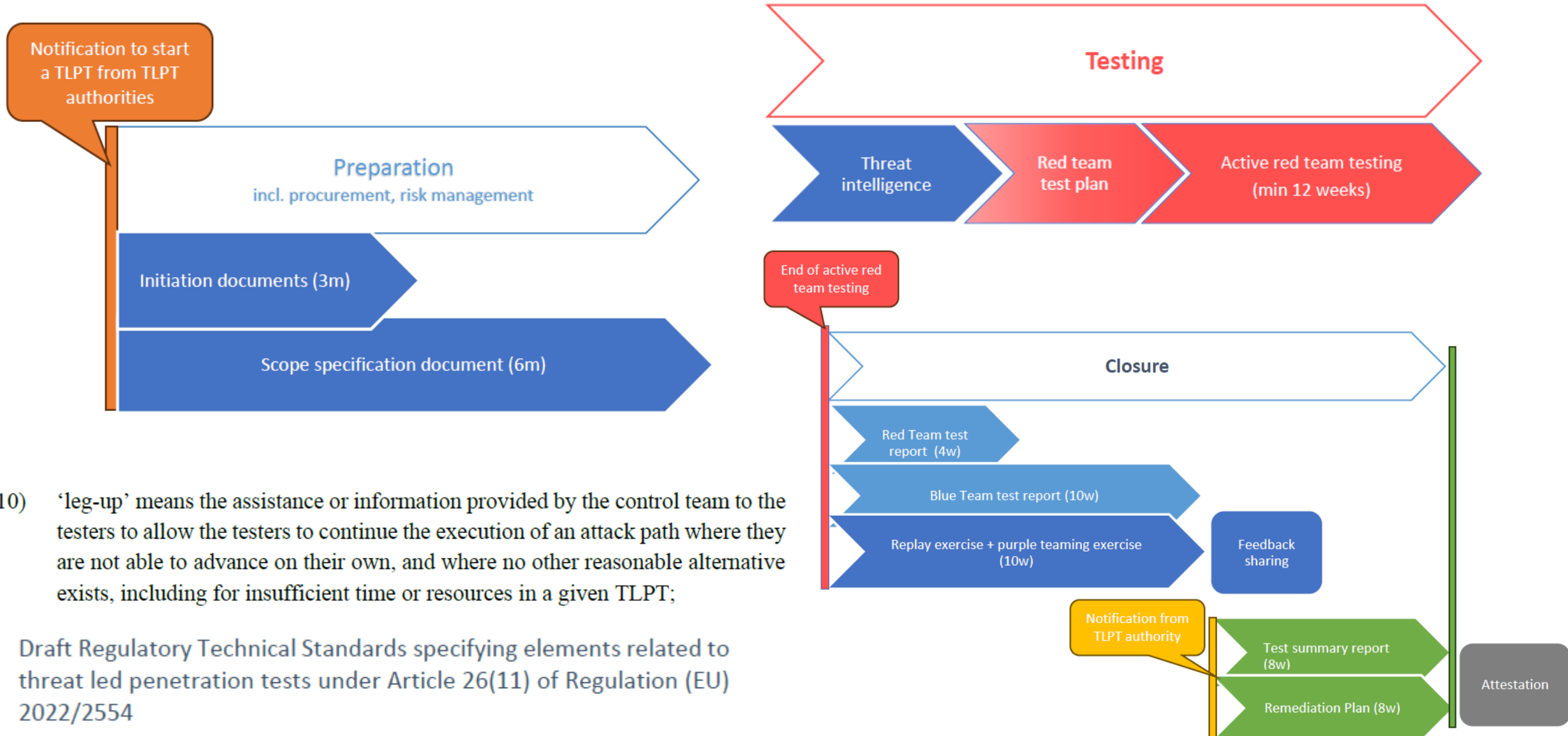
(i) testers and the threat intelligence provider are prohibited from the following activities:

- i. unauthorised destruction of equipment of the financial entity and of its ICT third-party service providers, if any;
- ii. uncontrolled modification of information and ICT assets of the financial entity and of its ICT third-party service providers, if any;
- iii. intentionally compromising the continuity of critical or important functions of the financial entity;
- iv. unauthorised inclusion of out-of-scope systems;
- v. unauthorised disclosure of test results.

7. During the entire active red team testing phase, testers shall report at least weekly to the control team and test managers on the progress made in the TLPT, and the threat intelligence provider shall remain available for consultation and additional threat intelligence when requested by the control team.
8. The control team shall timely provide leg-ups designed on the basis of the red team test plan. Leg-ups may be added or adapted upon approval by the control team and the test managers.
9. In case of detection of the testing activities by any staff member of the financial entity or of its ICT third-party service providers or ICT intragroup service provider, where relevant, the control team, in consultation with the testers and without prejudice to paragraph 10, shall propose and submit measures allowing to continue the TLPT while ensuring its secrecy to the test managers for validation.

Draft Regulatory Technical Standards specifying elements related to threat led penetration tests under Article 26(11) of Regulation (EU) 2022/2554

Digital operational resilience testing



Digital operational resilience testing

ANNEX III

Content of the targeted threat intelligence report

The targeted threat intelligence report shall include information on all of the following:

1. Overall scope of the intelligence research including at least the following:
 - a. critical or important functions in scope;
 - b. their geographical location;
 - c. official EU language in use;
 - d. relevant ICT third party services providers;
 - e. period of time over which the research is gathered.
2. Overall assessment of what concrete actionable intelligence can be found about the financial entity, such as:
 - a. employee usernames and passwords;
 - b. look-alike domains which can be mistaken for official domains of the financial entity;
 - c. technical reconnaissance: vulnerable and/or exploitable software, systems and technologies;
 - d. information posted by employees on social media, related to the financial entity, which might be used for the purposes of an attack;
 - e. information for sale on the dark web;
 - f. any other relevant information available on the internet or public networks;
 - g. where relevant, physical targeting information, including ways of access to the premises of the financial entity.
3. Threat intelligence analysis considering the general threat landscape and the particular situation of the financial entity, including, at least:
 - a. Geopolitical environment;
 - b. Economic environment;

Draft Regulatory Technical Standards specifying elements related to threat led penetration tests under Article 26(11) of Regulation (EU) 2022/2554

- c. Technological trends and any other trends related to the activities in the financial services sector;
4. Threat profiles of the malicious actors (specific individual/group or generic class) that may target the financial entity, including the systems of the financial entity that malicious actors are most likely to compromise or target, the possible motivation, intent and rationale for the potential targeting and the possible modus operandi of the attackers.
5. Threat scenarios: At least three end-to-end threat scenarios for the threat profiles identified in accordance with point 4 who exhibit the highest threat severity scores. The threat scenarios shall describe the end-to-end attack path and shall include, at least:
 - a. one scenario that includes but is not limited to compromised service availability;
 - b. one scenario that includes but is not limited to compromised data integrity;
 - c. one scenario that includes but is not limited to compromised information confidentiality.
6. Where relevant, description of the scenario referred to in Article 7(4).

Digital operational resilience testing

Draft Regulatory Technical Standards specifying elements related to threat led penetration tests under Article 26(11) of Regulation (EU) 2022/2554

ANNEX IV

Content of the red team test plan

The red team test plan shall include information on all of the following:

- (i) communication channels and procedures;
- (ii) the tactics, techniques and procedures allowed and not-allowed for use in the attack including ethical boundaries for social engineering, and how the privacy of involved parties is being safeguarded;
- (iii) risk management measures to be followed by the testers;
- (iv) a description for each scenario, including:
 - a. the simulated threat actor;
 - b. their intent, motivation and goals;
 - c. the target function(s) and the supporting ICT system or systems;
 - d. the targeted confidentiality, integrity, availability and authenticity aspects;
 - e. flags;
- (v) a detailed description of each expected attack path, including pre-requisites and possible leg-ups to be provided by the control team, including deadlines for their provision and potential usage;
- (vi) scheduling of red teaming activities, including time planning for the execution of each scenario, at a minimum split according to the three phases a tester takes throughout the testing phase, respectively entering financial entities' ICT systems, moving through the ICT systems and ultimately executing actions on objectives and eventually extracting itself from the ICT systems (in, through and out phases);
- (vii) particularities of the financial entities' infrastructure to be considered during testing;
- (viii) if any, additional information or other resources necessary to the testers for executing the scenarios.

ANNEX V

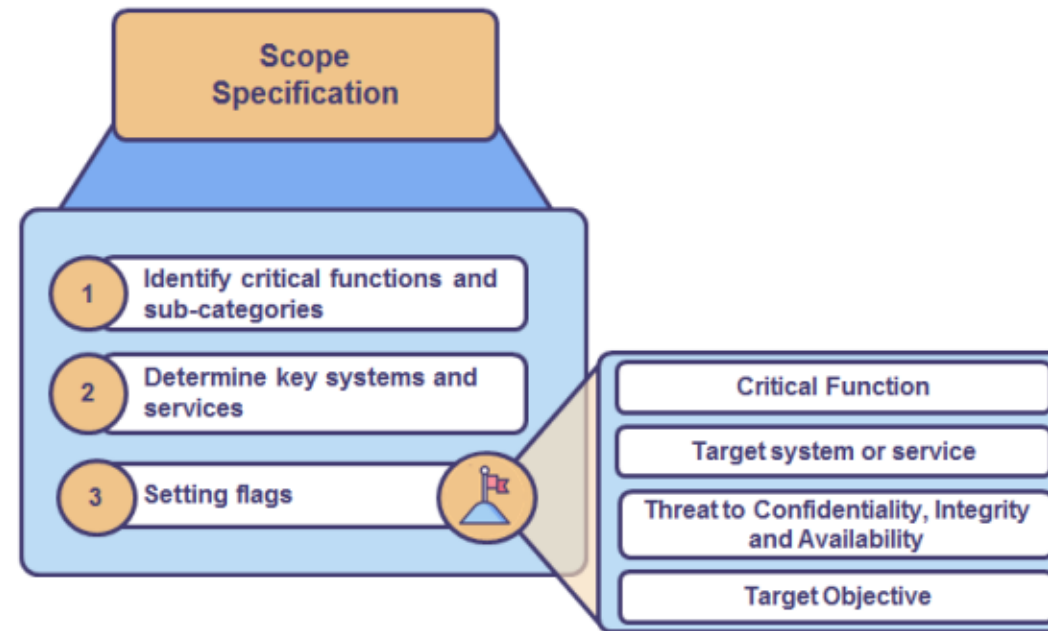
Content of the red team test report

The red team test report shall include information on at least all of the following:

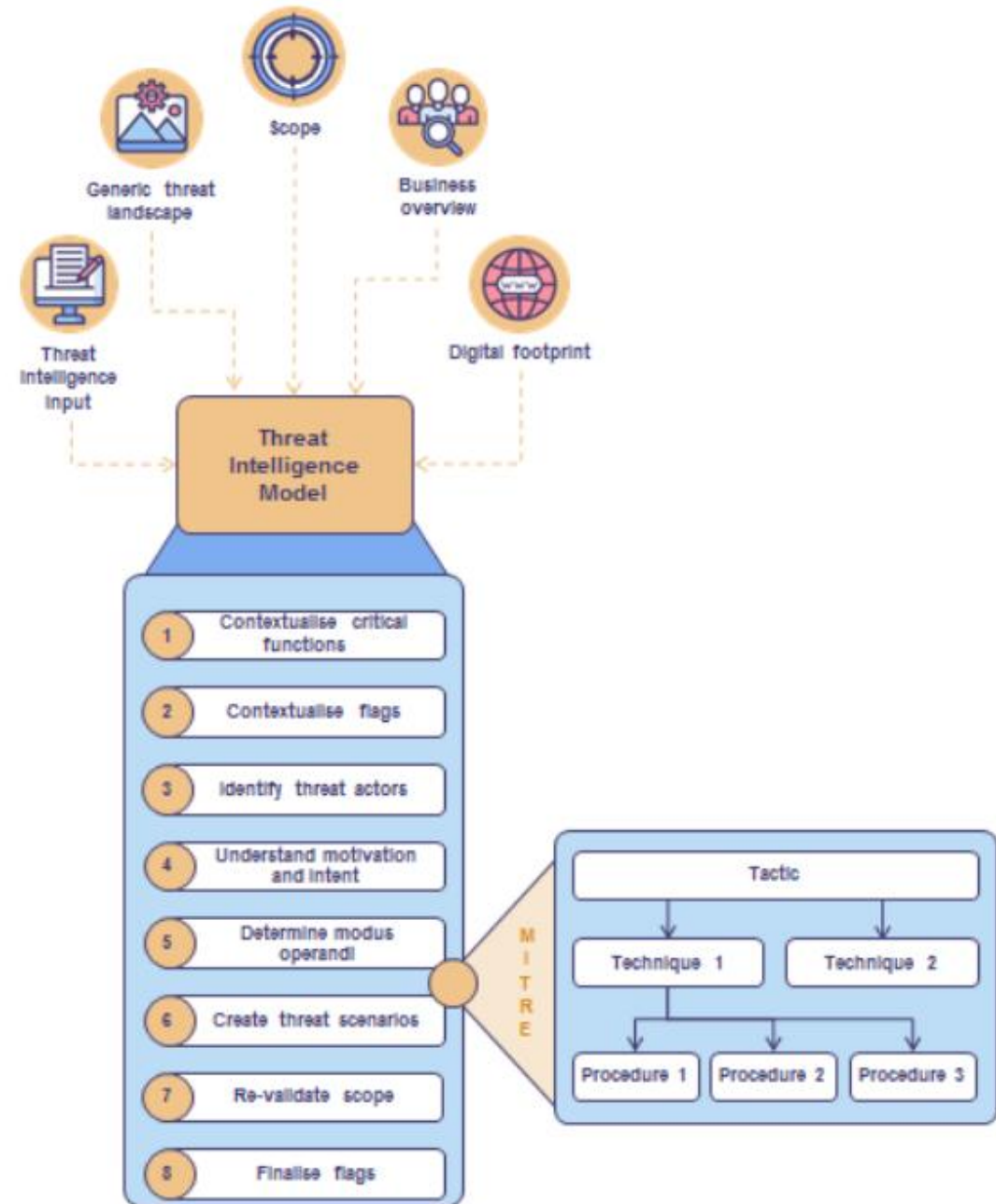
- (a) Information on the performed attack, including:
 - a. the targeted critical or important functions and identified ICT systems, processes and technologies supporting the critical or important function, as identified in the red team test plan;
 - b. summary of each scenario;
 - c. flags reached and not reached;
 - d. attack paths followed successfully and unsuccessfully;
 - e. tactics, techniques and procedures used successfully and unsuccessfully;
 - f. deviations from the red team test plan, if any;
 - g. leg-ups granted, if any;
- (b) All actions that the testers are aware of that were performed by the blue team to reconstruct the attack and to mitigate its effects;
- (c) discovered vulnerabilities and other findings, including:
 - a. vulnerability and other finding description including their criticality;
 - b. root cause analysis of successful attacks;
 - c. recommendations for remediation including indication of the remediation priority.

<https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/html/index.ro.html>

TIBER GUIDANCE



TIBER GUIDANCE

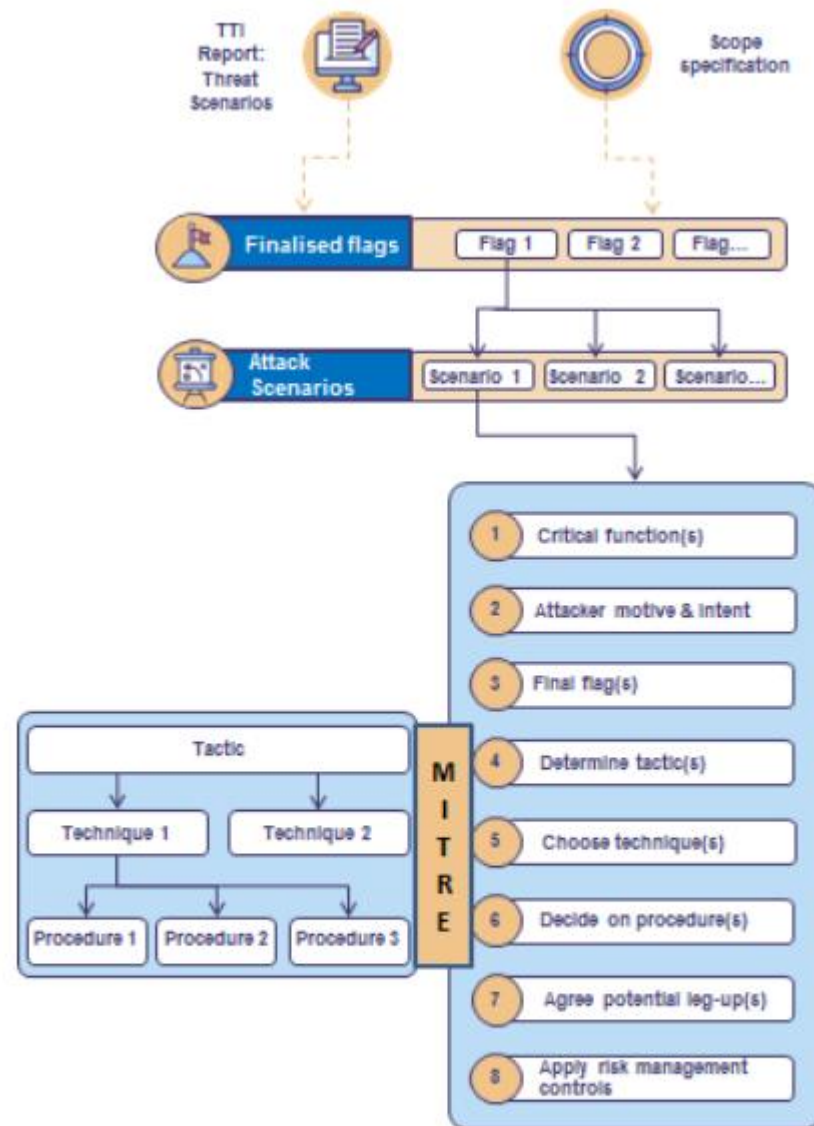


<https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/html/index.ro.html>

Source: https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/shared/pdf/Final_TIBER-EU_Guidance_for_Target_Threat_Intelligence_July_2020.pdf

TIBER GUIDANCE

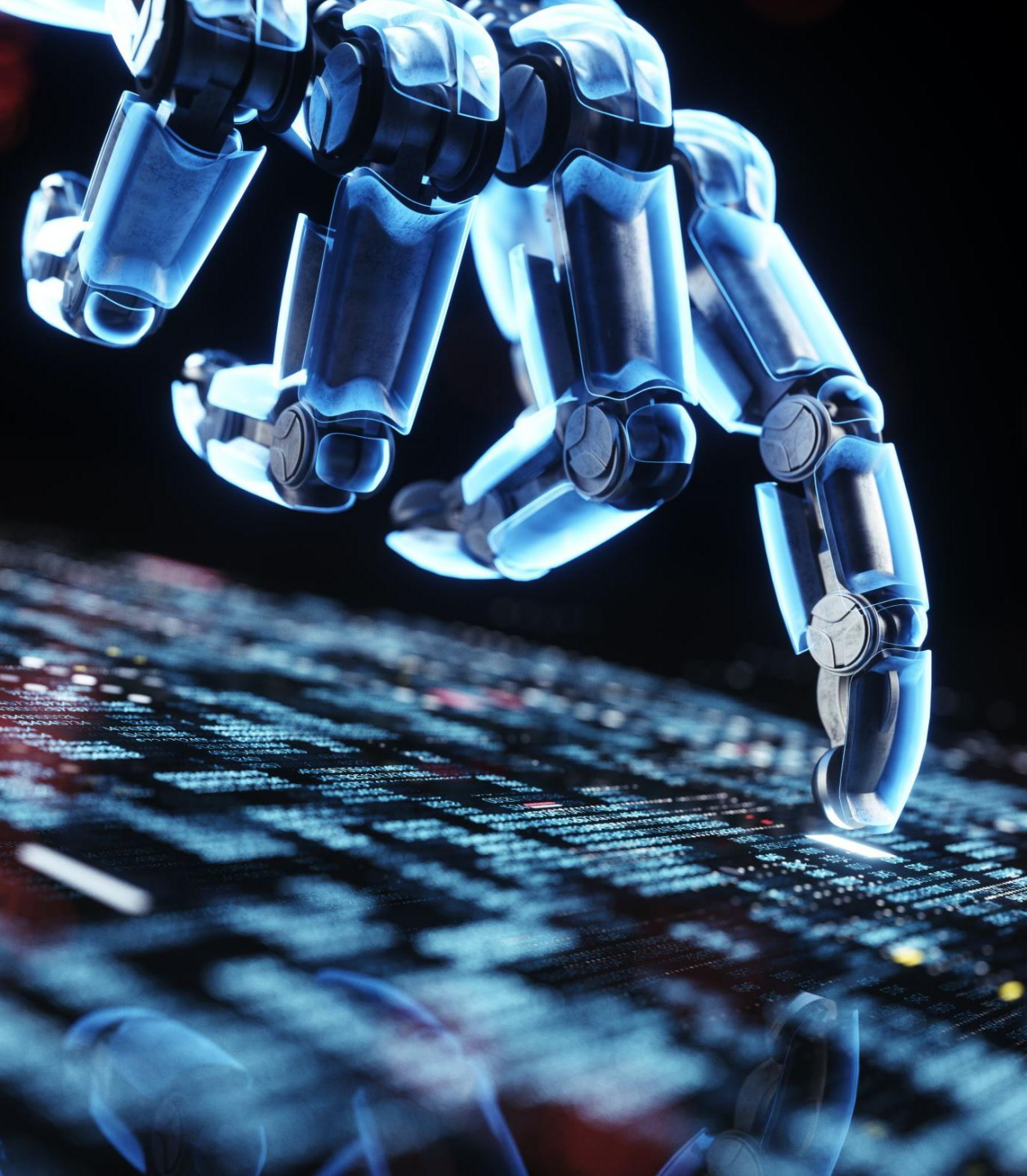
<https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/html/index.ro.html>



Source: https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/shared/pdf/Final_TIBER-EU_Guidance_for_the_Red_Team_Test_Plan_July_2020.pdf

ICT providers

- Risk assessment - initial, upon RFP process and when signing the contract
- Continuous monitoring and auditing - KPIs, periodical review, periodical audits
- Contractual obligations - certain specific mandatory obligations to be included.
- Incident management - including the 3rd party in the incident management process
- Exit strategy - detailed overview of steps to be taken in case the vendor has to be changed and/or the application to be migrated and/or the data to be migrated to another application
- Registry of ICT providers – very detailed information about providers



Cyber Resilience Act

Cyber Resilience Act

- EU Regulation – directly applicable in each Member State
- Entrance into force in 2027
- not applicable to medical devices
- not applicable to vehicles

Article 2

Scope

1. This Regulation applies to products with digital elements made available on the market, the intended purpose or reasonably foreseeable use of which includes a direct or indirect logical or physical data connection to a device or network.

(1) 'product with digital elements' means a software or hardware product and its remote data processing solutions, including software or hardware components being placed on the market separately;

(2) 'remote data processing' means data processing at a distance for which the software is designed and developed by the manufacturer, or under the responsibility of the manufacturer, and the absence of which would prevent the product with digital elements from performing one of its functions;

(22) 'making available on the market' means the supply of a product with digital elements for distribution or use on the Union market in the course of a commercial activity, whether in return for payment or free of charge;

Cyber Resilience Act

Article 6

Requirements for products with digital elements

Products with digital elements shall be made available on the market only where:

- (a) they meet the essential cybersecurity requirements set out in Part I of Annex I, provided that they are properly installed, maintained, used for their intended purpose or under conditions which can reasonably be foreseen, and, where applicable, the necessary security updates have been installed; and
- (b) the processes put in place by the manufacturer comply with the essential cybersecurity requirements set out in Part II of Annex I.

Critical products with digital elements - Annex IV – additional requirements

Requirement of a conformity assessment for the following types of products, as set out in Annex III:

- (a) the product with digital elements primarily performs functions critical to the cybersecurity of other products, networks or services, including securing authentication and access, intrusion prevention and detection, end-point security or network protection;
- (b) the product with digital elements performs a function which carries a significant risk of adverse effects in terms of its intensity and ability to disrupt, control or cause damage to a large number of other products or to the health, security or safety of its users through direct manipulation, such as a central system function, including network management, configuration control, virtualisation or processing of personal data.

Cyber Resilience Act

Article 13

Obligations of manufacturers

1. When placing a product with digital elements on the market, manufacturers shall ensure that it has been designed, developed and produced in accordance with the essential cybersecurity requirements set out in Part I of Annex I.
2. For the purpose of complying with paragraph 1, manufacturers shall undertake an assessment of the cybersecurity risks associated with a product with digital elements and take the outcome of that assessment into account during the planning, design, development, production, delivery and maintenance phases of the product with digital elements with a view to minimising cybersecurity risks, preventing incidents and minimising their impact, including in relation to the health and safety of users.
5. For the purpose of complying with paragraph 1, manufacturers shall exercise due diligence when integrating components sourced from third parties so that those components do not compromise the cybersecurity of the product with digital elements, including when integrating components of free and open-source software that have not been made available on the market in the course of a commercial activity.
6. Manufacturers shall, upon identifying a vulnerability in a component, including in an open source-component, which is integrated in the product with digital elements report the vulnerability to the person or entity manufacturing or maintaining the component, and address and remediate the vulnerability in accordance with the vulnerability handling requirements set out in Part II of Annex I. Where manufacturers have developed a software or hardware modification to address the vulnerability in that component, they shall share the relevant code or documentation with the person or entity manufacturing or maintaining the component, where appropriate in a machine-readable format.

- Obligations in case of creating software to comply with cybersecurity requirements (including due diligence for third party components used)
- Obligations throughout the lifecycle of the software in terms of ensuring security thereof

Cyber Resilience Act

Without prejudice to the second subparagraph, the support period shall be at least five years. Where the product with digital elements is expected to be in use for less than five years, the support period shall correspond to the expected use time.

9. Manufacturers shall ensure that each security update, as referred to in Part II, point (8), of Annex I, which has been made available to users during the support period, remains available after it has been issued for a minimum of 10 years or for the remainder of the support period, whichever is longer.

Cyber Resilience Act

Article 14

Reporting obligations of manufacturers

1. A manufacturer shall notify any actively exploited vulnerability contained in the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that actively exploited vulnerability via the single reporting platform established pursuant to Article 16.
2. For the purposes of the notification referred to in paragraph 1, the manufacturer shall submit:
 - (a) an early warning notification of an actively exploited vulnerability, without undue delay and in any event within 24 hours of the manufacturer becoming aware of it, indicating, where applicable, the Member States on the territory of which the manufacturer is aware that their product with digital elements has been made available;
 - (b) unless the relevant information has already been provided, a vulnerability notification, without undue delay and in any event within 72 hours of the manufacturer becoming aware of the actively exploited vulnerability, which shall provide general information, as available, about the product with digital elements concerned, the general nature of the exploit and of the vulnerability concerned as well as any corrective or mitigating measures taken, and corrective or mitigating measures that users can take, and which shall also indicate, where applicable, how sensitive the manufacturer considers the notified information to be;
 - (c) unless the relevant information has already been provided, a final report, no later than 14 days after a corrective or mitigating measure is available, including at least the following:
 - (i) a description of the vulnerability, including its severity and impact;
 - (ii) where available, information concerning any malicious actor that has exploited or that is exploiting the vulnerability;
 - (iii) details about the security update or other corrective measures that have been made available to remedy the vulnerability.

Obligation of software manufacturers to report vulnerabilities in the software they created

Cyber Resilience Act

Obligation of the manufacturer of software to report any security incident concerning the software it created

3. A manufacturer shall notify any severe incident having an impact on the security of the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that incident via the single reporting platform established pursuant to Article 16.

4. For the purposes of the notification referred to in paragraph 3, the manufacturer shall submit:

- (a) an early warning notification of a severe incident having an impact on the security of the product with digital elements, without undue delay and in any event within 24 hours of the manufacturer becoming aware of it, including at least whether the incident is suspected of being caused by unlawful or malicious acts, which shall also indicate, where applicable, the Member States on the territory of which the manufacturer is aware that their product with digital elements has been made available;
- (b) unless the relevant information has already been provided, an incident notification, without undue delay and in any event within 72 hours of the manufacturer becoming aware of the incident, which shall provide general information, where available, about the nature of the incident, an initial assessment of the incident, as well as any corrective or mitigating measures taken, and corrective or mitigating measures that users can take, and which shall also indicate, where applicable, how sensitive the manufacturer considers the notified information to be;
- (c) unless the relevant information has already been provided, a final report, within one month after the submission of the incident notification under point (b), including at least the following:
 - (i) a detailed description of the incident, including its severity and impact;
 - (ii) the type of threat or root cause that is likely to have triggered the incident;
 - (iii) applied and ongoing mitigation measures.

5. For the purposes of paragraph 3, an incident having an impact on the security of the product with digital elements shall be considered to be severe where:

- (a) it negatively affects or is capable of negatively affecting the ability of a product with digital elements to protect the availability, authenticity, integrity or confidentiality of sensitive or important data or functions; or
- (b) it has led or is capable of leading to the introduction or execution of malicious code in a product with digital elements or in the network and information systems of a user of the product with digital elements.

Cyber Resilience Act

Article 15

Voluntary reporting

1. Manufacturers as well as other natural or legal persons may notify any vulnerability contained in a product with digital elements as well as cyber threats that could affect the risk profile of a product with digital elements on a voluntary basis to a CSIRT designated as coordinator or ENISA.
2. Manufacturers as well as other natural or legal persons may notify any incident having an impact on the security of the product with digital elements as well as near misses that could have resulted in such an incident on a voluntary basis to a CSIRT designated as coordinator or ENISA.
3. The CSIRT designated as coordinator or ENISA shall process the notifications referred to in paragraphs 1 and 2 of this Article in accordance with the procedure laid down in Article 16.

The CSIRT designated as coordinator may prioritise the processing of mandatory notifications over voluntary notifications.

4. Where a natural or legal person other than the manufacturer notifies an actively exploited vulnerability or a severe incident having an impact on the security of a product with digital elements in accordance with paragraph 1 or 2, the CSIRT designated as coordinator shall without undue delay inform the manufacturer.

Obligation to report
vulnerabilities in their
software

Cyber Resilience Act

Article 19

Obligations of importers

1. Importers shall place on the market only products with digital elements that comply with the essential cybersecurity requirements set out in Part I of Annex I and where the processes put in place by the manufacturer comply with the essential cybersecurity requirements set out in Part II of Annex I.
2. Before placing a product with digital elements on the market, importers shall ensure that:
 - (a) the appropriate conformity assessment procedures as referred to in Article 32 have been carried out by the manufacturer;
 - (b) the manufacturer has drawn up the technical documentation;
 - (c) the product with digital elements bears the CE marking referred to in Article 30 and is accompanied by the EU declaration of conformity referred to in Article 13(20) and the information and instructions to the user as set out in Annex II in a language which can be easily understood by users and market surveillance authorities;
 - (d) the manufacturer has complied with the requirements set out in Article 13(15), (16) and (19).

For the purposes of this paragraph, importers shall be able to provide the necessary documents proving the fulfilment of the requirements set out in this Article.

3. Where an importer considers or has reason to believe that a product with digital elements or the processes put in place by the manufacturer are not in conformity with this Regulation, the importer shall not place the product on the market until that product or the processes put in place by the manufacturer have been brought into conformity with this Regulation. Furthermore, where the product with digital elements presents a significant cybersecurity risk, the importer shall inform the manufacturer and the market surveillance authorities to that effect.

Where an importer has reason to believe that a product with digital elements may present a significant cybersecurity risk in light of non-technical risk factors, the importer shall inform the market surveillance authorities to that effect. Upon receipt of such information, the market surveillance authorities shall follow the procedures referred to in Article 54(2).

Importers of software from third countries (outside the EU) have to ensure that these comply with proper cybersecurity requirements, as outlined in the Cyber Resilience Act

Cyber Resilience Act

Article 20

Obligations of distributors

1. When making a product with digital elements available on the market, distributors shall act with due care in relation to the requirements set out in this Regulation.
2. Before making a product with digital elements available on the market, distributors shall verify that:
 - (a) the product with digital elements bears the CE marking;
 - (b) the manufacturer and the importer have complied with the obligations set out in Article 13(15), (16), (18), (19) and (20) and Article 19(4), and have provided all necessary documents to the distributor.
3. Where a distributor considers or has reason to believe, on the basis of information in its possession, that a product with digital elements or the processes put in place by the manufacturer are not in conformity with the essential cybersecurity requirements set out in Annex I, the distributor shall not make the product with digital elements available on the market until that product or the processes put in place by the manufacturer have been brought into conformity with this Regulation. Furthermore, where the product with digital elements poses a significant cybersecurity risk, the distributor shall inform, without undue delay, the manufacturer and the market surveillance authorities to that effect.

Distributors of software from third countries (outside the EU) have to ensure that these comply with proper cybersecurity requirements, as outlined in the Cyber Resilience Act

Cyber Resilience Act

Article 24

Obligations of open-source software stewards

1. Open-source software stewards shall put in place and document in a verifiable manner a cybersecurity policy to foster the development of a secure product with digital elements as well as an effective handling of vulnerabilities by the developers of that product. That policy shall also foster the voluntary reporting of vulnerabilities as laid down in Article 15 by the developers of that product and take into account the specific nature of the open-source software steward and the legal and organisational arrangements to which it is subject. That policy shall, in particular, include aspects related to documenting, addressing and remediating vulnerabilities and promote the sharing of information concerning discovered vulnerabilities within the open-source community.

2. Open-source software stewards shall cooperate with the market surveillance authorities, at their request, with a view to mitigating the cybersecurity risks posed by a product with digital elements qualifying as free and open-source software.

Further to a reasoned request from a market surveillance authority, open-source software stewards shall provide that authority, in a language which can be easily understood by that authority, with the documentation referred to in paragraph 1, in paper or electronic form.

3. The obligations laid down in Article 14(1) shall apply to open-source software stewards to the extent that they are involved in the development of the products with digital elements. The obligations laid down in Article 14(3) and (8) shall apply to open-source software stewards to the extent that severe incidents having an impact on the security of products with digital elements affect network and information systems provided by the open-source software stewards for the development of such products.

Article 25

Security attestation of free and open-source software

In order to facilitate the due diligence obligation set out in Article 13(5), in particular as regards manufacturers that integrate free and open-source software components in their products with digital elements, the Commission is empowered to adopt delegated acts in accordance with Article 61 to supplement this Regulation by establishing voluntary security attestation programmes allowing the developers or users of products with digital elements qualifying as free and open-source software as well as other third parties to assess the conformity of such products with all or certain essential cybersecurity requirements or other obligations laid down in this Regulation.

Open source software –
cyber security
requirements

ANNEX I

ESSENTIAL CYBERSECURITY REQUIREMENTS

Part I Cybersecurity requirements relating to the properties of products with digital elements

- (1) Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.
- (2) On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall:
 - (a) be made available on the market without known exploitable vulnerabilities;
 - (b) be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state;
 - (c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;
 - (d) ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;
 - (e) protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;
 - (f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;
 - (g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);

Cyber Resilience Act

Essential cybersecurity
requirements – procedural,
technical, operational

Cyber Resilience Act

- (h) protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks;
- (i) minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;
- (j) be designed, developed and produced to limit attack surfaces, including external interfaces;
- (k) be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;
- (l) provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;
- (m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.

Part II Vulnerability handling requirements

Manufacturers of products with digital elements shall:

- (1) identify and document vulnerabilities and components contained in products with digital elements, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products;

Essential cybersecurity requirements – procedural, technical, operational

Cyber Resilience Act

- (2) in relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay, including by providing security updates; where technically feasible, new security updates shall be provided separately from functionality updates;
- (3) apply effective and regular tests and reviews of the security of the product with digital elements;
- (4) once a security update has been made available, share and publicly disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements affected, the impacts of the vulnerabilities, their severity and clear and accessible information helping users to remediate the vulnerabilities; in duly justified cases, where manufacturers consider the security risks of publication to outweigh the security benefits, they may delay making public information regarding a fixed vulnerability until after users have been given the possibility to apply the relevant patch;
- (5) put in place and enforce a policy on coordinated vulnerability disclosure;
- (6) take measures to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in third-party components contained in that product, including by providing a contact address for the reporting of the vulnerabilities discovered in the product with digital elements;
- (7) provide for mechanisms to securely distribute updates for products with digital elements to ensure that vulnerabilities are fixed or mitigated in a timely manner and, where applicable for security updates, in an automatic manner;
- (8) ensure that, where security updates are available to address identified security issues, they are disseminated without delay and, unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken.

Essential cybersecurity requirements – procedural, technical, operational



Question?

Thank you!